Caio Xavier da Silva

Análise Estática Generativa com LLMs: Otimizando a Detecção de Vulnerabilidades no SemGrep via Abordagem Multi-Agente

São Paulo
2026

Caio Xavier da Silva

Análise Estática Generativa com LLMs: Otimizando a Detecção de Vulnerabilidades no SemGrep via Abordagem Multi-Agente

Trabalho de Conclusão de Curso II apresentado ao SENAC Santo Amaro como requisito parcial para conclusão do curso de Bacharelado em Ciência da Computação.

SENAC – Serviço Nacional de Aprendizagem Comercial
Unidade Santo Amaro
Bacharelado em Ciência da Computação

Orientador: Eduardo Heredia
Coorientador: Thyago Conchado Quintas

São Paulo
2026

Resumo

As ferramentas de análise estática são fundamentais na detecção precoce de vulnerabilidades de *software*, porém as abordagens tradicionais enfrentam limitações devido à dependência de lógicas rígidas criadas manualmente, o que prejudica a escalabilidade e a detecção de *corner-cases*. Em contrapartida, a aplicação direta de Modelos de Linguagem de Larga Escala (LLMs) para o escaneamento integral de bases de código acarreta custos computacionais proibitivos e riscos de alucinação. Diante deste cenário, o objetivo deste trabalho é desenvolver e avaliar um *framework* multi-agente baseado em LLMs, capaz de sintetizar e otimizar automaticamente regras de análise estática para a ferramenta SemGrep, com foco em vulnerabilidades críticas (CWEs) da linguagem C. A pesquisa adota a metodologia *Design Science Research* (DSR) e propõe um ciclo de quatro fases: construção de um *dataset* baseado no Juliet Test Suite e históricos de *commits* reais, geração de regras por agentes LLM, avaliação rigorosa de métricas (Precisão, *Recall* e F1-Score) e aplicação prática em projetos de código aberto. Os resultados confirmam essa hipótese de forma parcial: em duas das cinco categorias de CWE avaliadas (CWE-416 e CWE-415), as regras sintetizadas superaram a regra tradicional equivalente do registro público do SemGrep em *recall* e F1-Score, em todas as sementes de validação cruzada testadas (*recall* de 89,2% a 100% contra 17,4%, para o CWE-416; de 43,3% a 76,3% contra 28,7%, para o CWE-415). Para as demais três categorias (CWE-401, CWE-457 e CWE-476), nenhuma configuração testada atingiu o critério interno de aprovação, e uma investigação dedicada identificou a causa como um limite de expressividade da própria linguagem de padrões do SemGrep, não do modelo gerador ou da estratégia de busca empregada. Modelos de linguagem de menor escala mostraram-se tecnicamente viáveis para a execução completa do *framework* em infraestrutura local, reduzindo a necessidade de engenharia manual, ainda que com desempenho inferior a modelos maiores em mecanismos de correção mais refinados.

Palavras-chave: análise estática. semgrep. LLM. regras. C.

Abstract

Static analysis tools are fundamental to the early detection of software vulnerabilities, but traditional approaches face limitations due to their dependence on rigid, manually crafted logic, which hampers scalability and the detection of corner cases. Conversely, directly applying Large Language Models (LLMs) to scan entire codebases incurs prohibitive computational costs and hallucination risks. Given this scenario, the objective of this work is to develop and evaluate a multi-agent LLM-based *framework* capable of automatically synthesizing and optimizing static analysis rules for the SemGrep tool, focusing on critical C-language vulnerabilities (CWEs). The research adopts the *Design Science Research* (DSR) methodology and proposes a four-phase cycle: building a dataset based on the Juliet Test Suite and real commit histories, rule generation by LLM agents, rigorous metric evaluation (Precision, Recall, and F1-Score), and practical application on open-source projects. The results partially confirm the hypothesis: for two of the five CWE categories evaluated (CWE-416 and CWE-415), the synthesized rules outperformed the equivalent traditional rule from SemGrep's public registry in recall and F1-Score, across every cross-validation seed tested (recall of 89.2% to 100% versus 17.4% for CWE-416; 43.3% to 76.3% versus 28.7% for CWE-415). For the remaining three categories (CWE-401, CWE-457, and CWE-476), no tested configuration met the internal approval criterion, and a dedicated investigation traced the cause to an expressiveness limit of SemGrep's own pattern language, rather than the generator model or the search strategy employed. Smaller-scale language models proved technically viable for running the complete framework on local infrastructure, reducing the need for manual engineering, although with lower performance than larger models on more refined correction mechanisms.

Keywords: static analysis. semgrep. LLM. rules. C.

Lista de Figuras

Figura 1 – Motivação para *checkers* feitos por LLMs. 14
Figura 2 – *Self-Attention* de LLMs. (TEMPORARIO) 15
Figura 3 – Exemplo de regra criada para detectar uma senha embutida no argumento da função em Python. 17
Figura 4 – *Query* utilizada durante a pesquisa de materiais. 23
Figura 5 – Funil de pesquisa. 24
Figura 6 – Árvore Sintática Abstrata para a expressão 9-5+2 26
Figura 7 – Exemplo de regra simplificada para detecção de falhas OSCI em Java. . 30
Figura 8 – *Overview* do KNighter 45
Figura 9 – Arquitetura do pipeline proposto 54
Figura 10 – *Pipeline* para gerador de regras. 55
Figura 11 – Pós-processamento para otimizar regras e abranger *corner-cases* 55
Figura 12 – Falsos positivos por configuração – evolução da regra do CWE-416 (Tabela 5) 64
Figura 13 – *Recall* por semente – CWE-415 frente ao piso do *gate* e à regra tradicional 66
Figura 14 – Comparação visual: regra tradicional *versus* melhor regra sintetizada (CWE-416 e CWE-415) 72

Lista de Tabelas

Tabela 1 – Limitações da análise estática tradicional 12
Tabela 2 – Comparação técnica entre os trabalhos relacionados 52
Tabela 3 – Combinações de modelos de linguagem avaliadas 59
Tabela 4 – Síntese dos melhores resultados por CWE 62
Tabela 5 – Evolução da configuração de referência para o CWE-416 (combo D, formato `template`, cinco sementes) 64
Tabela 6 – *Recall* por semente de particionamento – configuração de referência do CWE-415 (combo D, `yaml`, `example_mode=graph`) 65
Tabela 7 – Efeito de `example_mode=graph` sobre a combinação D no CWE-416 . . 68
Tabela 8 – Experimentos finais de diagnóstico – CWE-401 e CWE-476 70
Tabela 9 – Comparação entre as regras sintetizadas e um analisador tradicional (registro público do SemGrep, pacote `r/c`) 72

Lista de Abreviaturas e Siglas

A lista a seguir reúne, em ordem alfabética, as abreviaturas e siglas utilizadas neste trabalho, acompanhadas de seus respectivos significados.

Abreviatura	**Significado**
AST	*Abstract Syntax Tree* (Árvore de Sintaxe Abstrata)
APR	*Automated Program Repair* (Reparo de Programa Automatizado)
BNF	*Backus-Naur Form* (Forma de Backus-Naur)
CFG	*Control Flow Graphs* (Grafos de Fluxo de Controle); também usado, em outro sentido, para *Context-Free Grammar* (Gramática Livre de Contexto, Seção 2.2.3)
CNN	*Convolucional Neural Networks* (Redes Neurais Convolucionais)
CSA	*Clang Static Analyser*
CVE	*Common Vulnerabilities and Exposures* (Enumeração Comum de Vulnerabilidades e Exposições)
CWE	*Common Weakness Enumeration* (Enumeração de Fraquezas Comuns)
DFA	*Data Flow Analysis* (Análise de Fluxo de Dados)
DoS	*Denial of Service* (Negação de Serviço)
DSR	*Design Science Research*
FIA	*Flow-Insensitive Analysis* (Análise Insensível ao Fluxo)
FN	*False Negative* (Falsos Negativos)
FP	*False Positive* (Falsos Positivos)
IA	Inteligência Artificial

Abreviatura	**Significado**
FSA	*Flow-Sensitive Analysis* (Análise Sensível ao Fluxo)
KLOC	*Thousand Lines of Code* (Mil Linhas de Código)
LLM	*Large Language Models* (Modelos de Larga Escala)
NLG	*Natural Language Generation* (Geração de Linguagem Natural)
NLP	*Natural Language Processing* (Processamento de Linguagem Natural)
NLU	*Natural Language Understanding* (Compreensão de Linguagem Natural)
OSCI	*Operating System Command Injection* (Injeção de Comandos no Sistema Operacional)
RL	*Reinforcement Learning* (Aprendizado por Reforço)
RNN	*Recurrent Neural Network* (Redes Neurais Recorrentes)
UAF	*Use After Free* (Uso Após Liberação)
SAST	*Static Application Security Testing*
SFDR	*Sampled False Discovery Rate* (Taxa de Falsas Descobertas Amostradas)
TN	*True Negative* (Verdadeiros Negativos)
TP	*True Positive* (Verdadeiros Positivos)

Sumário

1 INTRODUÇÃO 11
1.1 Contextualização do problema 13
1.2 Formulação do problema 17
1.3 Objetivos e hipótese 18
1.3.1 Objetivo geral 18
1.3.2 Objetivos específicos 19
1.3.3 Hipótese ou critério de validação 20
1.4 Justificativa 21

2 REVISÃO BIBLIOGRÁFICA / TRABALHOS RELACIONADOS . . 23
2.1 Metodologia da pesquisa bibliográfica 23
2.2 Fundamentos teóricos 25
2.2.1 Análise Estática Tradicional 25
2.2.1.1 Árvore Sintática Abstrata 25
2.2.1.2 Grafos de Fluxo de Controle 26
2.2.1.3 Análise de Fluxo de Dados 27
2.2.1.4 Sensibilidade de Fluxo 28
2.2.1.5 Limitações da Análise Estática 29
2.2.1.6 Análise estática baseada em regras 29
2.2.2 Vulnerabilidades de Linguagem 31
2.2.2.1 *Common Vulnerabilities and Exposures* 32
2.2.2.2 *Common Weakness Enumeration* 32
2.2.2.3 CWE-401 33
2.2.2.4 CWE-415 34
2.2.2.5 CWE-416 34
2.2.2.6 CWE-457 35
2.2.2.7 CWE-476 35
2.2.3 Linguagem Natural 36
2.2.3.1 Processamento de Linguagem Natural 36
2.2.4 Arquitetura *Transformer* 37
2.2.4.1 Modelos de Linguagens de Grande Escala 39
2.2.4.2 Agentes e Sistemas Multi-Agentes 41
2.2.5 Métricas de Avaliação 42
2.2.5.1 Juliet Test Suite 42
2.2.5.2 Validade Gramatical 42

2.2.5.3 Validade Funcional . . . 42
2.2.5.4 Validação em *Dataset* . . . 43
2.2.5.5 Validação no mundo real . . . 44
2.2.5.6 Custo . . . 44
2.3 Trabalhos correlatos . . . 44
2.3.1 Trabalho 1: *KNighter: Transforming Static Analysis with LLM-Synthesized Checkers* (YANG et al., 2025) . . . 45
2.3.2 Trabalho 2: *Generation, Migration and Optimization of Cross-Language Static-Analysis Rules Based on Large Language Models* (HOU et al., 2025) 47
2.3.3 Trabalho 3: *RepoAudit: An Autonomous LLM-Agent for Repository-Level Code Auditing* (GUO et al., 2025) . . . 49
2.3.4 Síntese comparativa . . . 51

3 DESENVOLVIMENTO / IMPLEMENTAÇÃO / EXPERIMENTOS 53
3.1 Metodologia da pesquisa . . . 53
3.2 Detalhes da implementação . . . 53
3.2.1 Visão geral da solução proposta . . . 53
3.2.2 Arquitetura do trabalho . . . 54
3.2.3 Arquitetura efetivamente implementada . . . 55
3.2.4 Formatos de saída das regras . . . 57
3.2.5 O analisador de grafos de eventos: um componente complementar e determinístico . . . 57
3.2.6 Combinações de modelos avaliadas . . . 58
3.2.7 Protocolo de avaliação . . . 59
3.3 Experimentos e cenário de testes . . . 60
3.3.1 Rodada 1: viabilidade do formato de preenchimento de lacunas (CWE-457) 60
3.3.2 Rodadas 2 a 4: mecanismo `field_correct` (CWE-416 e CWE-415) . . . 61
3.3.3 Revisão da configuração de referência e rodada final (CWE-416) . . . 61
3.4 Resultados e análises . . . 62
3.4.1 CWE-457: um alvo estruturalmente inadequado . . . 62
3.4.2 Mecanismo `field_correct`: um ganho real, porém inconsistente . . . 63
3.4.3 CWE-416: da aprovação isolada à melhoria consistente . . . 63
3.4.4 CWE-415 e a necessidade metodológica de múltiplas sementes . . . 65
3.4.5 O que não foi alcançado: síntese das tentativas sem sucesso e alternativas . 66
3.4.6 Comparação com um analisador estático tradicional . . . 71

4 CONCLUSÃO . . . 74
4.1 Retomada do problema e dos objetivos . . . 74
4.2 Contribuições para a Computação . . . 75
4.3 Limitações e trabalhos futuros . . . 76

REFERÊNCIAS BIBLIOGRÁFICAS 78

1 Introdução

Para dimensionar o problema tratado neste trabalho, basta observar o que acontece quando uma falha de *software* passa despercebida. Em 2014, a ausência de uma única verificação de tamanho em uma rotina de manipulação de memória da biblioteca OpenSSL, escrita em C e utilizada para proteger a comunicação de grande parte dos *sites* da internet, deu origem à vulnerabilidade conhecida como *Heartbleed* (CVE-2014-0160) (DURUMERIC et al., 2014).

A falha permitia que qualquer pessoa lesse trechos da memória dos servidores afetados, expondo senhas, dados pessoais e chaves criptográficas. Estima-se que, no momento da divulgação, entre 24% e 55% dos servidores HTTPS do milhão de *sites* mais acessados do mundo estavam vulneráveis (DURUMERIC et al., 2014). O código CVE-2014-0160 que identifica a falha vem do catálogo CVE (*Common Vulnerabilities and Exposures*), que atribui um identificador público e único a cada vulnerabilidade divulgada em uma versão específica de um *software*, para que equipes e ferramentas de segurança saibam que estão se referindo ao mesmo problema (CVE Program, 2026). O catálogo é apresentado na Seção 2.2.2.1.

Esse caso não é isolado. A Microsoft relata que cerca de 70% das vulnerabilidades de seus produtos às quais atribui um CVE a cada ano são problemas de segurança de memória (THOMAS, 2019). A equipe do navegador Chromium, do Google, chegou a uma proporção semelhante ao analisar 912 falhas de severidade alta ou crítica registradas desde 2015: cerca de 70% eram problemas de segurança de memória, e metade destas, do tipo uso de memória após a sua liberação (The Chromium Projects, [2020]).

Em linguagens como C, o programador é responsável por reservar e devolver manualmente a memória utilizada. Esquecer de liberá-la (vazamento de memória), liberá-la duas vezes ou continuar usando um endereço já liberado são erros simples de cometer e difíceis de perceber, mas que podem travar sistemas inteiros ou permitir que um invasor execute código malicioso.

Esses tipos de erro são catalogados pela CWE (*Common Weakness Enumeration*), uma lista mantida pela comunidade que descreve fraquezas comuns de *software*, isto é, condições no código que, sob determinadas circunstâncias, podem dar origem a vulnerabilidades (MITRE Corporation, 2026a). Enquanto um CVE identifica uma vulnerabilidade concreta em um produto, uma CWE descreve o tipo de erro que a causou: o uso de memória já liberada, por exemplo, corresponde à CWE-416. Este trabalho se concentra em cinco dessas categorias, todas relacionadas a erros de memória em C, apresentadas na Seção 2.2.2.2.

Ferramentas de análise estática são amplamente empregadas no desenvolvimento de *software* e garantia de código (HOU et al., 2025). Por essa abordagem não necessitar de compilação e execução prévia do sistema, ela é considerada um método rápido e

econômico para a identificação de problemas em seus estágios iniciais. Segundo Jiang et al. (2025), as ferramentas de análise estática emergiram como componentes indispensáveis nos fluxos de trabalhos, fornecendo mecanismos automatizados para detecção de defeitos, vulnerabilidades de segurança e violações de padrões de codificação.

Em termos simples, essas ferramentas funcionam como um revisor automático que lê o código em busca de padrões perigosos, sem precisar executá-lo. Os detalhes de como essa leitura é feita, por meio de estruturas como árvores de sintaxe e grafos de fluxo, são apresentados na Seção 2.2.1.

Tabela 1 – Limitações da análise estática tradicional

Limitação	**Descrição**
Escalabilidade e Diversidade de *Bugs*	A dependência de verificações pré-definidas ou modelagens formais restringe as ferramentas a um subconjunto limitado de padrões de *bugs*. Isso prejudica a escalabilidade e a capacidade de detectar vulnerabilidades imprevistas ou casos extremos (*corner-cases*) (YANG et al., 2025).
Esforço Humano	A configuração de verificações personalizadas exige um alto nível de especialização técnica. A complexidade sintática torna a tarefa inacessível para desenvolvedores comuns, sendo inviável mesmo com treinamento de curto prazo para realizar uma heurística eficiente (HOU et al., 2025). Pesquisas revelam que menos de 5% das lógicas de detecção utilizadas na indústria são criadas por usuários comuns (HOU et al., 2025).
Falta de Extensibilidade Multilinguagem	A maioria dos analisadores é desenvolvida com lógica rigidamente codificada (*hard-coded*) para uma linguagem de programação específica. A necessidade de construir e manter *parsers* específicos para cada nova linguagem exige alta especialização técnica, o que inviabiliza a portabilidade e gera altos custos na adaptação de analisadores para ecossistemas poliglotas (HOU et al., 2025).
Falsos Positivos e Falsos Negativos	Devido à complexidade dos sistemas de *software* e à riqueza de gramáticas de programação, é inviável que verificações manuais estáticas prevejam todas as variações estruturais. Essa generalização falha resulta em uma abundância de alarmes imprecisos no mundo real (JIANG et al., 2025).

Fonte: Elaborado pelo autor (2026)

Apesar de sua eficácia, a implementação tradicional dessas ferramentas frequentemente depende de heurísticas pré-definidas, modelagens formais ou conjuntos de regras criadas manualmente para identificar padrões de falhas. Uma vez que as vulnerabilidades são detectadas, o próximo desafio no ciclo de desenvolvimento é a sua correção.

Em resposta às limitações da detecção de falhas, o campo de Reparo de Programa Automatizado, em inglês *Automated Program Repair* (APR), consolidou-se como uma área

de pesquisa na engenharia de *software*. Enquanto a análise estática tradicional se limita a apontar as violações, o APR propõe-se a dar um passo além: gerar automaticamente soluções e aplicar correções de código (*patches*) sem intervenção humana, visando reduzir os custos de depuração (TANG et al., 2021).

Contudo, apesar de sua utilidade, tanto as ferramentas clássicas de detecção quanto os métodos tradicionais de correção enfrentam graves desafios estruturais. Conforme apontado por Hou et al. (2025) e Tang et al. (2021), a eficácia destas abordagens é frequentemente limitada por sua dependência de lógica rígida, o que compromete severamente a sua extensibilidade. A Tabela 1 sintetiza as principais limitações destas abordagens clássicas apontadas na literatura.

1.1 Contextualização do problema

Um alarme falso, ou falso positivo, ocorre quando a ferramenta aponta como defeituoso um trecho de código que está correto; já um falso negativo é uma falha real que a ferramenta não consegue detectar. Ambos são prejudiciais: se a maior parte dos avisos for falsa, os desenvolvedores deixam de confiar na ferramenta e passam a ignorá-la (AHO et al., 2007), enquanto os falsos negativos permitem que vulnerabilidades cheguem ao usuário final.

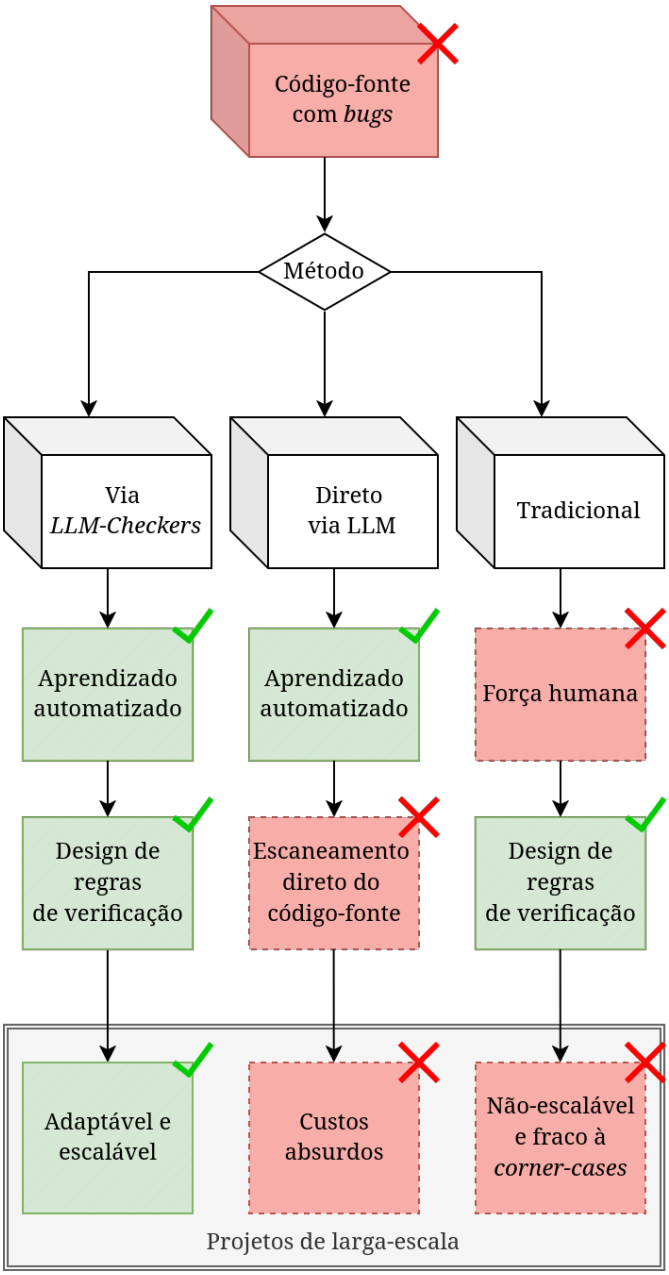
Nos últimos anos, muitas técnicas foram desenvolvidas para minimizar alarmes falsos em analisadores estáticos (JIANG et al., 2025). Recentemente, Modelos de Linguagem de Grande Porte (LLMs) passaram a ser incorporados ao domínio da análise estática. Eles não substituem as ferramentas tradicionais, que continuam em uso por serem determinísticas e capazes de percorrer bases de código com milhões de linhas (YANG et al., 2025); em vez disso, atuam em conjunto com elas, de duas formas.

Na primeira, o LLM examina diretamente o código-fonte ou os dados produzidos pelas próprias ferramentas de análise estática para determinar a presença, a localização e o tipo de *bugs* (HOU et al., 2025). Na segunda, o LLM gera as regras ou os verificadores que a ferramenta tradicional executa, unindo a capacidade de generalização do modelo à escalabilidade da análise estática (HOU et al., 2025; YANG et al., 2025). É nesta segunda forma que se insere este trabalho.

Modelos de Linguagem de Larga Escala possuem o conhecimento prévio adquirido durante seu pré-treinamento em vastos repositórios de código aberto. Durante a inferência, essas capacidades podem ser direcionadas via engenharia de *prompt* (como o fornecimento de históricos de *commits* de correção no contexto) para extrair padrões sintáticos e semânticos de *bugs* específicos do sistema (TANG et al., 2021). A capacidade de analisar vários conteúdos sugere que LLMs são capazes de se adaptar a novos tipos de falhas sem a necessidade de criação explícita de verificações específicas (YANG et al., 2025).

Um LLM não lê o texto caractere a caractere: a entrada é dividida em *tokens*, unidades que podem corresponder a palavras inteiras, partes de palavras ou símbolos, como os

Figura 1 – Motivação para *checkers* feitos por LLMs.



Fonte: Adaptado pelo autor para melhor compreensão (YANG et al., 2025)

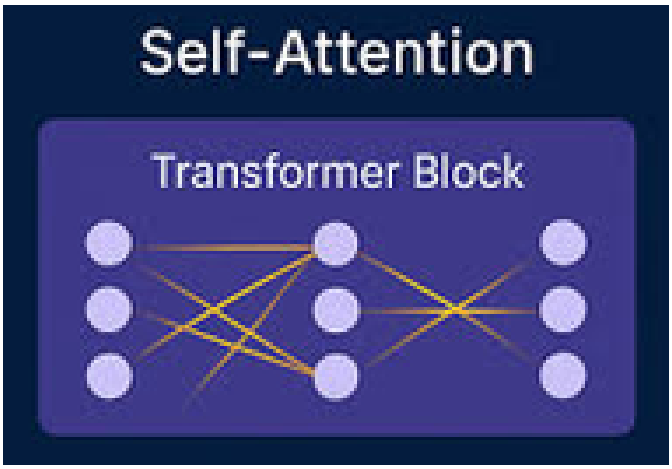
operadores de uma linguagem de programação. A quantidade máxima de *tokens* que o modelo consegue processar de uma só vez é chamada de janela de contexto; ao gerar cada *token*, o modelo tem acesso a todos os *tokens* anteriores dentro dessa janela, mas a nenhum que esteja fora dela (JURAFSKY; MARTIN, 2026). Na prática, a janela determina quanto código e quanta instrução cabem em uma única consulta ao modelo.

Embora os modelos de linguagem desenvolvidos até o ano de 2026 possuam janelas de contexto na ordem de milhões de *tokens*, a inspeção direta e contínua do código-fonte esbarra em severas restrições práticas e custos proibitivos. A raiz dessa limitação está na arquitetura *Transformer* (VASWANI et al., 2017), sobre a qual os LLMs atuais são

construídos. Trata-se de uma rede neural formada por uma pilha de camadas que, em vez de ler o texto palavra a palavra, como as redes recorrentes, processa todos os *tokens* da entrada de uma só vez.

O componente central de cada camada é o mecanismo de autoatenção (*self-attention*): para cada *token*, o modelo calcula um peso de relevância em relação a cada um dos demais *tokens* da sequência e combina as representações destes de acordo com esses pesos. É isso que permite relacionar, por exemplo, o uso de uma variável à sua declaração feita muitas linhas antes. A Figura 2 ilustra essa ideia: cada círculo corresponde a um *token*, e as linhas entre duas colunas indicam que cada *token* de uma camada é calculado a partir de todos os *tokens* da camada anterior, ponderados pelos pesos de atenção. A arquitetura e o cálculo da atenção são detalhados na Seção 2.2.4.

Figura 2 – *Self-Attention* de LLMs. (TEMPORARIO)



Fonte: Elaborado pelo autor(2026)

Essa comparação de todos os *tokens* com todos os outros é justamente o que limita o tamanho da entrada. Para uma sequência de n *tokens*, a autoatenção calcula $n \times n$ pesos, e Vaswani et al. (2017) indicam para ela um custo por camada de $O(n^2 \cdot d)$, em que d é a dimensão das representações. Como essa matriz de pesos também precisa ser mantida em memória, o consumo de memória da atenção cresce igualmente de forma quadrática com o tamanho da sequência (DAO et al., 2022): dobrar o tamanho da entrada quadruplica esse custo. Como consequência, a submissão integral de bases de código de projetos em larga escala, como o *kernel* do Linux, provoca uma explosão nos requisitos de processamento (TUNSTALL; WERRA; WOLF, 2022).

Estudos empíricos confirmam que essa abordagem pode consumir dezenas de milhões de *tokens* e exigir dias de processamento contínuo, criando uma limitação crítica para a escalabilidade das ferramentas (HOU et al., 2025). Essa sobrecarga de contexto exacerba o risco de alucinações da inteligência artificial, induzindo o modelo a gerar inferências estruturalmente plausíveis, porém tecnicamente incorretas.

Para contornar as limitações da janela de contexto e o alto custo da inferência direta por um único modelo, ferramentas recentes de detecção de vulnerabilidades baseadas em LLMs têm adotado fluxos de trabalho com agentes e sistemas multi-agentes, nos quais uma tarefa complexa é decomposta entre agentes coordenados, cada um responsável por uma subtarefa localizada. Um agente inteligente é fundamentalmente uma entidade computacional que percebe o seu ambiente e age sobre ele de alguma forma (RUSSELL; NORVIG, 2020). Em vez de submeter bases de código gigantescas a uma única instância de inteligência artificial, o processamento é descentralizado e distribuído entre múltiplos agentes.

O RepoAudit, um agente baseado em LLM para auditoria de repositórios de código, por exemplo, parte justamente da constatação de que a janela de contexto limitada e o custo em tempo e em *tokens* impedem que um LLM audite um repositório inteiro de uma só vez; em vez disso, seu agente explora a base de código sob demanda, função por função, e submete os resultados a um módulo validador para reduzir alucinações (GUO et al., 2025).

Em um ambiente cooperativo, a comunicação e a divisão de tarefas entre os agentes emergem como comportamentos racionais essenciais para a resolução de problemas complexos (RUSSELL; NORVIG, 2020). Dessa forma, cada agente LLM assume um papel restrito e especializado, como abstração, síntese de sintaxe ou validação, colaborando de forma iterativa para reduzir a sobrecarga de *tokens* e aumentar a precisão na geração do artefato final.

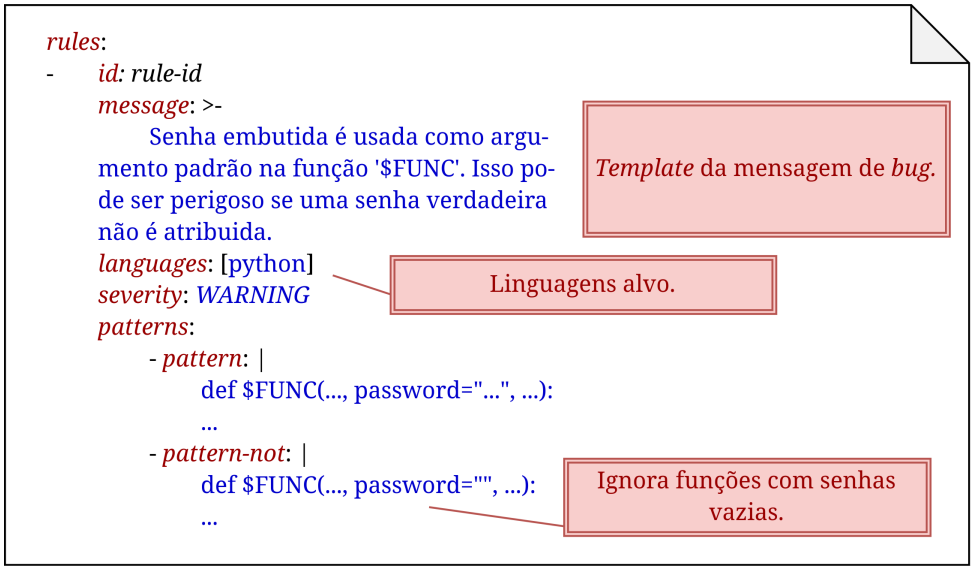
A figura 1 introduz motivações para a necessidade de métodos mais eficientes e, principalmente, especializados, tal que em projetos grandes, a análise estática possui dois desafios: criar regras para diversos padrões de bugs e gerenciamento de bases de códigos imensas (YANG et al., 2025). Considerando esses dados, o analisador estático ideal deveria: detectar uma diversidade de falhas, incluindo *corner-cases* e semânticas específicas de sistemas, e eficientemente processar milhões de linhas de código. Porém, dos métodos existentes, geralmente sacrificam um desses objetivos (YANG et al., 2025).

Uma proposta nessa direção é o KNighter (YANG et al., 2025), um sistema que usa LLMs para gerar automaticamente verificadores (*checkers*) para o *Clang Static Analyzer* (CSA), analisador estático de código C. Em vez de pedir ao LLM que leia o código inteiro em busca de falhas, o KNighter fornece a ele um *commit* que corrigiu um *bug* real. A partir dessa correção, o LLM descreve o padrão do *bug* e escreve um verificador especializado nesse padrão, que só é aceito se apontar o código anterior à correção como defeituoso e o código corrigido como correto. A varredura da base de código é então feita pelo próprio CSA, e não pelo LLM, o que contorna os limites da janela de contexto e o custo de analisar projetos com milhões de linhas, como o *kernel* do Linux (YANG et al., 2025). Assim como o RepoAudit, o KNighter também recorre a agentes auxiliares: um deles corrige erros de sintaxe nos verificadores gerados, e outro faz a triagem dos alarmes que esses verificadores

produzem, descartando os falsos (YANG et al., 2025). O funcionamento do KNighter é detalhado na Seção 2.3.1.

Uma alternativa ao uso de analisadores construídos do zero são as ferramentas de análise estática baseadas em regras, como o SemGrep. O SemGrep é uma ferramenta de código aberto na qual o usuário descreve, em arquivos no formato YAML, regras cujos padrões imitam a própria sintaxe da linguagem analisada, como ilustra a Figura 3 (HOU et al., 2025).

Figura 3 – Exemplo de regra criada para detectar uma senha embutida no argumento da função em Python.



Fonte: Adaptado para português com finalidade de melhorar compreensão (HOU et al., 2025).

Ferramentas de análise estática costumam varrer o código com uma série de regras, chamada de conjunto de regras (*ruleset*); uma ferramenta para C++, por exemplo, pode ter um *ruleset* com verificações de vazamento de memória, de acesso fora dos limites de um vetor e de arquivos abertos e não fechados (HOU et al., 2025).

O SemGrep disponibiliza um *ruleset* oficial, que Hou et al. (2025) usam como referência para avaliar as regras geradas por LLMs; neste trabalho, é a esse conjunto que se refere a expressão *ruleset* tradicional. Por dispensar a construção de um analisador específico para cada tipo de falha, Hou et al. (2025) utilizam o SemGrep como base para as regras que geram por meio de LLMs, abordagem também adotada neste trabalho. Seu funcionamento é detalhado na Seção 2.2.1.6.

1.2 Formulação do problema

Como discutido na Seção 1.1, a análise estática em projetos de larga escala precisa conciliar dois objetivos: detectar uma diversidade de falhas, incluindo *corner-cases*, e processar bases de código com milhões de linhas. Submeter o código diretamente a um

LLM poderia ampliar a abrangência da detecção, mas esbarra nos limites da janela de contexto e no custo de inferência. Diante disso, este trabalho formula a seguinte pergunta de pesquisa:

> *Um framework multi-agente baseado em LLMs é capaz de sintetizar regras para o SemGrep que detectem vulnerabilidades em código C com recall e precisão estatisticamente superiores aos do ruleset tradicional da ferramenta?*

O escopo restringe-se à linguagem C, a cinco categorias de CWE (Seção 2.2.2.2) e ao SemGrep como motor de execução das regras. Não fazem parte do escopo a comparação com ferramentas de análise estática proprietárias nem a aplicação a outras linguagens de programação. A pergunta é desdobrada nos objetivos específicos (Seção 1.3.2) e na hipótese (Seção 1.3.3), e os resultados obtidos são discutidos no Capítulo 3.

1.3 Objetivos e hipótese

Os objetivos desta pesquisa estruturam-se em duas frentes: o objetivo geral, focado em solucionar o problema central do estudo, e os objetivos específicos, representam os subprodutos ou detalhamentos lógicos gerados para alcançar esse propósito maior.

1.3.1 Objetivo geral

O objetivo geral deste trabalho é demonstrar que um *framework* de síntese automatizada de regras, baseando-se em Modelos de Linguagem de Larga Escala e integrado à ferramenta SemGrep, apresenta precisão e *recall* estatisticamente superiores às abordagens estáticas tradicionais na detecção de vulnerabilidades críticas em linguagem C. Busca-se demonstrar que este modelo supera abordagens estáticas tradicionais na identificação precisa de, no mínimo, cinco categorias de vulnerabilidades de software, em inglês *Common Weakness Enumeration* (CWE).

Ao final da execução experimental (Capítulo 3), este objetivo foi apenas parcialmente alcançado. Conforme detalhado nas Seções 3.4.3 e 3.4.5, apenas uma das cinco categorias de CWE originalmente previstas (CWE-416) obteve alguma regra efetivamente aprovada pelo critério de validação definido, e de forma instável entre as sementes de particionamento avaliadas; nas demais quatro categorias (CWE-401, CWE-415, CWE-457 e CWE-476), nenhuma configuração testada atingiu os critérios mínimos de aprovação.

Como os critérios de sucesso de um objetivo de pesquisa devem ser definidos antes da execução, e não ajustados depois para se adequar ao resultado obtido (WAZLAWICK, 2020), o objetivo geral foi mantido em sua forma original, e a divergência entre o planejado e o alcançado é retomada no Capítulo 4.

1.3.2 Objetivos específicos

Sobre os objetivos específicos, temos:

1. Determinar os limites de detecção semântica (*corner-cases*) que podem ser superados pela abordagem gerativa de LLMs em relação aos conjuntos de regras predefinidas (*ruleset*) estáticos.

2. Avaliar o ganho quantitativo de desempenho (*Recall*, Precisão e F1-Score) de regras sintetizadas dinamicamente frente aos analisadores tradicionais do estado da arte.

3. Determinar a viabilidade técnica e a escalabilidade de inferência da arquitetura proposta utilizando modelos de linguagem de menor escala (com contagem reduzida de parâmetros), visando garantir a viabilidade técnica da execução do *framework* em infraestruturas locais com restrições de custo e *hardware*.

Avaliando-se retrospectivamente cada objetivo específico à luz dos resultados do Capítulo 3: o primeiro objetivo foi efetivamente alcançado, uma vez que o próprio processo experimental revelou um limite de detecção semântica claro e documentado para o CWE-457 (Seção 3.4.1), no qual a limitação não está no modelo gerador, mas no próprio motor de análise de fluxo de contaminação do SemGrep *Open Source*.

O segundo objetivo foi **parcialmente alcançado**: identificou-se, no registro público e gratuito do SemGrep, regras diretamente aplicáveis a duas das cinco categorias avaliadas – `c.lang.security.function-use-after-free`, para o CWE-416, e `c.lang.security.double-free`, para o CWE-415 –, que foram executadas sobre o mesmo subconjunto rotulado do Juliet Test Suite e comparadas, em *Recall*, precisão e F1-Score, com a melhor configuração sintetizada para cada CWE (Seção 3.4.6).

A regra tradicional obteve *recall* de 17,4% (F1 de 0,276) para o CWE-416 e de 28,7% (F1 de 0,364) para o CWE-415, contra *recall* de 89,2% a 100% (F1 de 0,72 a 0,91) e de 43,3% a 76,3% (F1 de 0,50 a 0,63), respectivamente, obtidos pelas regras sintetizadas neste trabalho – superioridade observada em todas as sementes avaliadas, sem exceção, para ambos os CWEs.

Em termos práticos, *recall* mede a proporção dos casos efetivamente vulneráveis do subconjunto avaliado que a regra consegue detectar – não quantos alertas a regra emite, mas quantos dos casos que *realmente contêm* a vulnerabilidade ela de fato sinaliza; cada caso vulnerável não detectado é um falso negativo, silenciosamente ignorado.

Para o CWE-416, a regra tradicional (17,4%) deixa de detectar cerca de cinco em cada seis ocorrências reais de uso após liberação presentes no subconjunto rotulado do Juliet Test Suite; a faixa de 89,2% a 100% obtida pela regra sintetizada neste trabalho significa que, em cada uma das cinco sementes de particionamento avaliadas (Seção 3.4.4), ao menos nove em cada dez casos vulneráveis de teste – nunca vistos durante a geração da regra – foram corretamente detectados, chegando à totalidade deles em algumas sementes.

Para o CWE-415, a regra tradicional (28,7%) deixa de detectar pouco mais de sete em cada dez ocorrências reais de liberação dupla; a faixa de 43,3% a 76,3% da regra sintetizada significa que, a depender da semente de particionamento, entre pouco menos da metade e pouco mais de três quartos dos casos vulneráveis de teste foram corretamente detectados – uma variação mais ampla entre sementes do que a observada no CWE-416, consistente com a maior instabilidade já documentada para este CWE (Seção 3.4.4), mas ainda assim superior à regra tradicional em todas as cinco sementes, sem exceção.

Em ambos os casos, o ganho de *recall* não é absoluto: a Tabela 9 mostra que, em algumas sementes, a precisão da regra sintetizada fica abaixo da precisão da regra tradicional, de modo que o ganho líquido medido pelo F1-Score – que pondera *recall* e precisão em uma única métrica –, discutido na Seção 3.4.6, é o indicador mais completo da comparação.

Para as demais três categorias (CWE-401, CWE-457 e CWE-476), nenhuma regra do registro gratuito do SemGrep mostrou-se relevante ao padrão de vulnerabilidade avaliado, de modo que a comparação quantitativa permanece indisponível para esses casos dentro do escopo gratuito investigado, lacuna ainda reconhecida como limitação no Capítulo 4.

O terceiro objetivo foi alcançado: a comparação entre as combinações de modelos (Seção 3.2.6) demonstrou empiricamente que modelos de menor escala (combinação C, 4 bilhões de parâmetros) são tecnicamente viáveis para a execução completa do *framework* em infraestrutura local, ainda que com desempenho inferior ao de modelos maiores (combinação D) em mecanismos de correção mais refinados, como o `field_correct` (Seção 3.4.2).

1.3.3 Hipótese ou critério de validação

A hipótese desta pesquisa é a de que a geração automatizada de regras por meio de um *framework* multi-agente baseado em LLMs, integrado ao motor do SemGrep, produzirá taxas de detecção (*Recall* e *F1-Score*) de vulnerabilidades (CWEs) em C estatisticamente superiores e com maior identificação de *corner-cases* quando comparada aos conjuntos de regras predefinidas dos analisadores estáticos tradicionais (como por exemplo *ruleset* tradicional do SemGrep).

Considerando os critérios de avaliação de hipóteses em pesquisa de Ciência da Computação (WAZLAWICK, 2020), esta hipótese é considerada **parcialmente confirmada**, com evidência mais direta do que a disponível na primeira redação deste capítulo. A superioridade estatística generalizada para as cinco categorias de CWE originalmente previstas não se sustenta diante dos dados coletados (Capítulo 3): apenas CWE-416 e CWE-415 permitiram uma comparação quantitativa direta contra um analisador tradicional, e as demais três categorias sequer foram aprovadas pelo critério de validação interno deste trabalho (Seção 3.4.5); nesse sentido, a hipótese é **refutada** em sua formulação mais ampla.

Por outro lado, para as duas categorias em que uma linha de base tradicional pôde ser estabelecida (Seção 3.4.6), a hipótese **não é refutada**: a melhor configuração sintetizada

para o CWE-416 atingiu *recall* de 89,2% a 100% e F1-Score de 0,72 a 0,91, contra 17,4% e 0,276 da regra tradicional equivalente do registro público do SemGrep; para o CWE-415, a melhor configuração atingiu *recall* de 43,3% a 76,3% e F1-Score de 0,50 a 0,63, contra 28,7% e 0,364 da regra tradicional – superando-a em *recall* nas cinco sementes avaliadas, sem exceção, em ambos os CWEs.

A hipótese é, portanto, refutada em sua formulação ampla (generalização irrestrita entre categorias de CWE) e sustentada por evidência quantitativa direta nos dois casos em que uma linha de base tradicional pôde ser estabelecida, conclusão discutida com maior profundidade na Seção 3.4.6 e retomada no Capítulo 4.

1.4 Justificativa

A literatura recente demonstra avanços significativos na aplicação de Modelos de Linguagem de Larga Escala, em inglês *Large Language Models* (LLM), para a análise estática, comprovando a viabilidade de sintetizar verificadores automatizados de código (HOU et al., 2025; YANG et al., 2025). Trabalhos recentes atestam que a integração de LLMs com ferramentas ágeis e baseadas em regras, como o SemGrep, supera as abordagens tradicionais de lógica rígida, permitindo uma maior flexibilidade e abrangência na identificação de vulnerabilidades (HOU et al., 2025; YANG et al., 2025).

Contudo, apesar das evoluções trazidas pelo estudo pioneiro de Yang et al. (2025), estudos publicados em 2025 e 2026 revelam que métodos baseados em LLMs ainda exibem uma cobertura limitada, frequentemente falhando em lidar com variações semânticas complexas e *corner-cases* (HOU et al., 2025; YANG et al., 2025). Porém estudos concluíram que métodos de análise estática baseado em LLMs identificam mais vulnerabilidades únicas do que métodos tradicionais (YANG et al., 2025; HOU et al., 2025).

Portanto, este trabalho justifica-se pela necessidade de preencher a atual lacuna de eficácia e escalabilidade na detecção de vulnerabilidades. O desenvolvimento de um *framework* iterativo, focado na geração automatizada de regras para o motor do SemGrep, é motivado por dois problemas concretos.

O primeiro é a dependência de engenharia manual: escrever regras de detecção exige conhecimento especializado, a ponto de menos de 5% das lógicas de detecção utilizadas na indústria serem criadas por usuários comuns (HOU et al., 2025).

O segundo é o custo da inferência direta por IAs: submeter projetos inteiros a um LLM pode consumir dezenas de milhões de *tokens* e exigir dias de processamento contínuo, o mesmo limite de escalabilidade já discutido na Seção 1.1 (HOU et al., 2025), o que inviabiliza o seu uso contínuo. Gerar as regras uma única vez e reutilizá-las no SemGrep, cuja execução não depende de LLMs, ataca os dois problemas simultaneamente.

Ao propor um sistema especializado nas vulnerabilidades críticas (CWEs) da linguagem C, essa pesquisa visa demonstrar que é possível identificar padrões semânticos e *corner-*

cases com maior precisão e viabilidade técnica do que os analisadores estáticos tradicionais ou métodos generalistas baseados exclusivamente em LLMs.

2 Revisão Bibliográfica / Trabalhos Relacionados

Este capítulo tem como finalidade estabelecer o embasamento teórico e tecnológico que sustenta a pesquisa proposta. Inicialmente, descreve-se a metodologia utilizada para a seleção dos trabalhos consultados. Na sequência, o referencial teórico explora os paradigmas da análise estática assistida por inteligência artificial, as limitações da análise dinâmica e os desafios inerentes à análise estática tradicional.

Os fundamentos técnicos são apresentados com ênfase em Modelos de Linguagem de Grande Escala (LLMs), Processamento de Linguagem Natural e os princípios de Análise Estática. Por fim, conduz-se uma revisão dos trabalhos correlatos, identificando as lacunas que esta pesquisa busca preencher.

2.1 Metodologia da pesquisa bibliográfica

A pesquisa bibliográfica foi conduzida de forma sistemática para identificar trabalhos científicos relevantes sobre a utilização de LLMs no suporte à análise estática. As buscas foram centralizadas no motor Google Acadêmico (*Google Scholar*), devido à sua ampla indexação, com foco principal em bases de dados consolidadas na área da Computação, como arXiv, IEEE Xplore e ACM Digital Library.

Para as buscas, foram definidas palavras-chave em inglês, tais como: *"static analysis"*, *"LLM"*, *"large language model"*, *"GPT"*, *"C"*, *"C++"*, *"rule generation"*, *"Linux kernel"*, *"pointer"*, *"undefined"*, *"memory"*, *"value-flow"* e *"SemGrep"*. Estes termos foram combinados por meio de operadores booleanos (*AND*, *OR*) para refinar os resultados, culminando na *string* de busca apresentada na Figura 4:

Figura 4 – *Query* utilizada durante a pesquisa de materiais.

```
"static analysis" AND ("LLM" OR "large language model" OR "GPT") AND ("C" OR "C++" OR
"Linux kernel") AND ("pointer" OR "undefined" OR "memory" OR "value-flow") AND
("SemGrep" OR "semgrep")
```

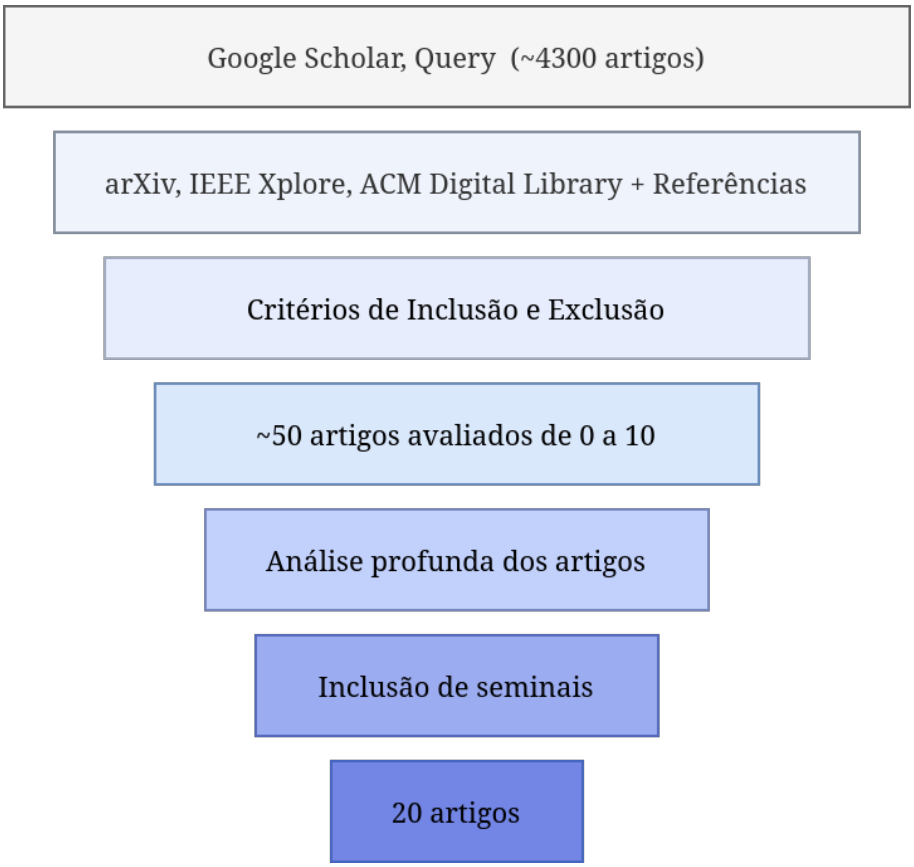
Fonte: Elaborado pelo autor (2026)

Como critérios de inclusão, estabeleceram-se: (a) trabalhos publicados entre 2021 e 2026, de forma a capturar o estado da arte; (b) disponibilidade nos idiomas inglês ou português; e (c) relação direta com o tema, priorizando artigos que contivessem implementações ou experimentos aplicados à utilização de LLMs para geração de regras para a linguagem C.

Em contrapartida, os critérios de exclusão adotados foram: (a) trabalhos publicados antes de 2021, com exceção de referências clássicas ou seminais indispensáveis para a teoria; (b) artigos sem alinhamento direto com análise estática ou geração de regras de código; e (c) duplicidades de publicações entre as bases de dados consultadas.

O processo de seleção ocorreu em duas etapas. Na primeira fase (triagem), a aplicação da *string* de busca retornou 4.770 resultados, dos quais foram selecionados 47 artigos potencialmente relevantes após a leitura prévia de títulos e resumos. Na segunda fase (afunilamento), os trabalhos restantes passaram por uma leitura criteriosa da introdução e do escopo, sendo classificados em uma escala de relevância de 0 a 10 em relação aos objetivos desta pesquisa.

Figura 5 – Funil de pesquisa.



Fonte: Elaborado pelo autor (2026)

A avaliação de 0 a 10 foi feita a partir de seu resumo, palavras-chave, tecnologia aplicada. Caso o trabalho possua similaridades com outros artigos bem avaliados é considerado como suporte ou alta relevância. Esse processo de filtragem resultou em 6 artigos classificados com notas entre 9 e 10 (alta relevância), além de 9 artigos categorizados como material de suporte, totalizando 15 trabalhos contemporâneos para compor a fundamentação teórica. Adicionalmente, foram incorporados 5 trabalhos seminais anteriores a 2021, essenciais para a consolidação dos conceitos clássicos abordados neste estudo.

2.2 Fundamentos teóricos

O referencial teórico apresenta os conceitos fundamentais que sustentam o desenvolvimento deste projeto. Propõe-se um contraponto analítico entre os métodos da análise estática tradicional e as novas abordagens voltadas à automatização da geração de regras.

A estruturação dos tópicos foi concebida para apresentar gradativamente as tecnologias envolvidas, destacando o papel das LLMs e sua relevância para a modernização das ferramentas de verificação de código na atualidade.

2.2.1 Análise Estática Tradicional

Verificações estáticas, segundo Aho et al. (2007), são checagens de consistência realizadas durante o processo de compilação, sendo possível capturar erros de programação cedo, antes da sua execução.

Incluindo dois tipos de análises: **(i) Verificação Sintática**, envolve a aplicação de restrições que não são aplicadas apenas pelas gramáticas, como um identificador ser declarado apenas uma vez dentro do escopo (AHO et al., 2007). **(ii) Verificação de Tipos**, assegura que as regras de tipagem da respectiva linguagem sejam seguidas, checando se os operadores ou funções estão sendo aplicados ao número ou tipo correto de operando. Se a conversão de tipos é necessária, o verificador pode inserir o operador correto na árvore de sintaxe para a conversão (AHO et al., 2007).

Não é importante somente para otimização de código, as mesmas técnicas podem ser usadas para analisar *software* já existentes para diversos padrões comuns de erros de programação (AHO et al., 2007). PREfix e Metal são duas ferramentas mencionadas por Aho et al. (2007) utilizam análise estática interprocedural, rastreando o fluxo de informações em um programa inteiro, para encontrar erros de programação estaticamente em grandes bases de código. Estas ferramentas são capazes de rastrear o caminho de entradas fornecidas pelos usuários enquanto essas *strings* são copiadas ou combinadas ao longo de vários procedimentos, acompanhando as entradas é possível prevenir contra *SQL Injection* e *Buffer Overflows* (AHO et al., 2007).

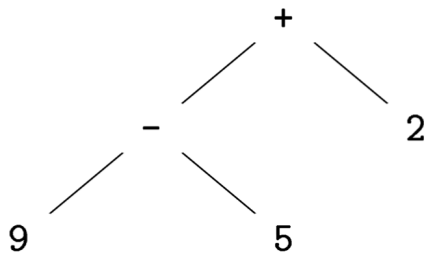
2.2.1.1 Árvore Sintática Abstrata

Durante o processo de análise sintática, é comum a geração de uma árvore de análise (*Parse Tree*), também conhecida como árvore de sintaxe concreta, onde os nós internos representam os símbolos não-terminais definidos pela gramática da linguagem (AHO et al., 2007). Contudo, para as fases subsequentes de compilação ou de análise estática de código, essa representação contém detalhes puramente estruturais que não afetam a semântica do programa (AHO et al., 2007).

A Árvore Sintática Abstrata, do inglês *Abstract Syntax Tree* (AST), surge como uma representação intermediária otimizada. Em uma AST, cada nó interno representa

um operador ou um constructo de programação, enquanto nós filhos representam os operandos ou os componentes semânticos daquele constructo (AHO et al., 2007). Nós auxiliares exigidos pela gramática para contornar ambiguidades ou definir precedência (como produções única ou parênteses) são descartados, resultando em uma estrutura de dados mais limpa e focada no significado das operações (AHO et al., 2007).

Figura 6 – Árvore Sintática Abstrata para a expressão 9-5+2



Fonte: (AHO et al., 2007)

Tomando como exemplo, na figura 6, a expressão matemática 9 - 5 + 2, a raiz da AST representaria o operador +, tendo como filho esquerdo a subexpressão correspondente a 9 - 5 e como filho direito a constante 2. Esse agrupamento estrutural reflete a precedência e a associatividade à esquerda dos operadores, tornando redundante a presença de nós sintáticos adicionais.

Em ferramentas de análise estática voltadas para linguagens complexas como C, operar sobre a AST é essencial, pois permite que a verificação de propriedades e a busca por vulnerabilidades sejam conduzidas diretamente sobre a lógica estrutural do código, isolando a análise de variações gramaticais irrelevantes (AHO et al., 2007).

No contexto da análise de vulnerabilidades, a AST é fundamental para identificar padrões estruturais perigosos. Ao invés de realizar buscas textuais limitadas, os analisadores percorrem a árvore em busca de composições específicas de nós.

Por exemplo, para detectar um risco de desreferenciação de ponteiro nulo (*Null Pointer Dereference*), uma regra de análise pode inspecionar a AST em busca de um nó que represente uma chamada de alocação de memória, como a função `devm_kzalloc`, verificando se não existe um nó condicional adjacente encarregado de checar o valor de retorno antes de sua utilização.

2.2.1.2 Grafos de Fluxo de Controle

Complementar à Árvore Sintática Abstrata (AST), utilizam-se os grafos de fluxo de controle, do inglês *Control Flow Graphs* (CFG). Enquanto a AST foca em representar hierarquicamente a sintaxe estrutural do código, o CFG é um grafo direcionado construído

para modelar os possíveis caminhos de execução do programa, sendo a base essencial para análises sensíveis ao fluxo (*flow-sensitive*) (AHO et al., 2007).

Representação em grafo de código intermediário é muito útil para a geração de código (AHO et al., 2007). De acordo com Aho et al. (2007), essa representação é construída em dois passos, primeiro, é particionado o código intermediário em blocos básicos (*basic blocks*), que atuam como os nós do grafo.

Um bloco básico é uma sequência máxima de instruções consecutivas de três endereços onde o fluxo de controle entra obrigatoriamente pela primeira instrução, sem saltos para o interior dele, e sai apenas pela última, sem interrupções ou ramificações em seu interior (AHO et al., 2007). As arestas relacionadas do grafo indicam as transições de controle (*control flow*) permitidas no programa, representando que a execução pode fluir do final de um bloco básico específico para o início de outro (AHO et al., 2007).

Na construção de um CFG, as instruções de desvio (*jumps*) endereçadas a linhas ou rótulos específicos são substituídas por referências diretas aos blocos básicos correspondentes. Essa abstração é fundamental na construção de compiladores, pois permite que otimizações subsequentes alterem livremente o conteúdo interno dos blocos sem invalidar os alvos dos desvios de controle (AHO et al., 2007). Caso não houvesse essa otimização, seria necessário corrigir os alvos toda vez que uma instrução fosse alterada.

CFGs podem ser representados na programação por qualquer estrutura de dados tradicional para grafos. Quanto ao conteúdo interno dos nós (blocos básicos), Aho et al. (2007) afirma que eles podem ser representados por um ponteiro para a primeira instrução e uma contagem de instruções. No entanto, como as otimizações alteram frequentemente a quantidade de instruções, costuma ser mais eficiente representar o conteúdo de cada bloco básico, ou nó, como uma lista encadeada (*linked list*) de instruções (AHO et al., 2007).

2.2.1.3 Análise de Fluxo de Dados

A Análise de Fluxo de Dados, em inglês *Data Flow Analysis* (DFA), é definida como um conjunto de técnicas que derivam informações sobre o fluxo de dados ao longo dos possíveis caminhos de execução de um programa (AHO et al., 2007).

Tradicionalmente fundamentais para as otimizações globais em compiladores, essas técnicas permitem determinar, por exemplo, se duas expressões avaliam para o mesmo valor em todos os caminhos possíveis ou se o resultado de uma atribuição nunca é utilizado (código morto) (AHO et al., 2007).

A execução de um programa é modelada como uma série de transformações do estado do programa, onde o estado consiste nos valores de todas as variáveis do programa em um dado momento (AHO et al., 2007). Cada instrução executada transforma um estado de entrada em um novo estado de saída.

No entanto, Aho et al. (2007) afirma que é impossível acompanhar todos os estados exatos devido ao número ilimitado de caminhos de execução. Por esse motivo, a DFA opera

através de abstrações, ignorando detalhes irrelevantes e guardando apenas as características essenciais para o objetivo da otimização (AHO et al., 2007).

É associado a cada ponto do programa um valor de fluxo de dados (que representa a abstrações dos estados possíveis) pertencente a um "domínio" (AHO et al., 2007). O problema de DFAs consiste em encontrar uma solução para dois conjuntos de restrições principais:

Funções de transferência (*Transfer Functions*), são restrições baseadas na semântica de cada instrução, pegando o valor do fluxo de dados antes da instrução e geram um novo valor de saída (AHO et al., 2007). O fluxo pode acontecer "para frente" (*forward*), onde a entrada molda a saída, ou "para trás" (*backward*), onde a direção desse fluxo é invertida.

Restrições de Fluxo de Controle (*Control-Flow Constraints*), definem como a informação transita de um bloco básico para outro dentro do CFG. Essencialmente, o valor do fluxo de dados que entra em uma instrução é matematicamente determinado pela combinação dos valores que saem das instruções ou blocos predecessores (AHO et al., 2007).

No contexto da segurança de *software* e da detecção de falhas abordadas neste trabalho, a abstração fornecida pela DFA é o motor principal que permite analisadores estáticos avançados identificarem vulnerabilidades complexas. É através do rastreamento do estado das variáveis pelos caminhos de controle que se torna viável detectar comportamentos críticos em linguagens como C, como *Null Pointer Dereference* (CWE-476) ou uso de variáveis não inicializadas (CWE-457).

2.2.1.4 Sensibilidade de Fluxo

A precisão de uma análise estática depende fortemente de sua sensibilidade ao fluxo de controle. Segundo Aho et al. (2007), as abordagens de análise (como a análise de apontamento de ponteiros) podem ser categorizadas em dois tipos principais:

Análise Sensível ao Fluxo, em inglês *Flow-Sensitive Analysis* (FSA), essa abordagem acompanha o fluxo de controle do programa e computa o estado exato (por exemplo, para onde cada variável pode apontar) após a execução de cada instrução individual Aho et al. (2007). Isso significa que a análise avalia as restrições e funções de transferência passo a passo; ela não apenas considera novas informações e relações que um comando gera (*generate*), mas também contabiliza as informações anteriores que o comando invalida ou mata (*kills*).

Análise Insensível ao Fluxo, em inglês *Flow-Insensitive Analysis* (FIA), em contrapartida, essa abordagem ignora o fluxo de controle, assumindo essencialmente que cada instrução do programa pode ser executada em qualquer ordem (AHO et al., 2007). A FIA computa apenas um mapa global indicando para onde cada variável possivelmente apontar em qualquer momento da execução do programa. Em uma análise insensível ao fluxo, uma atribuição nunca invalida (*kill*) relações de apontamento; ela apenas gera novas relações.

Ou seja, se uma variável puder apontar para dois objetos diferentes após a avaliação de duas instruções distintas, o sistema apenas registra e acumula a informação global de que ela aponta para ambos (AHO et al., 2007).

Aho et al. (2007) explicam que a falta de sensibilidade ao fluxo enfraquece consideravelmente a precisão dos resultados da análise, uma vez que produz superaproximações do estado real do programa. No entanto, essa abstração tem o benefício direto de reduzir drasticamente o tamanho da representação dos resultados e fazer com que o algoritmo termine de forma mais rápida, o que é frequentemente necessário ao analisar bases de código em larga escala.

2.2.1.5 Limitações da Análise Estática

Aho et al. (2007) explicam que o problema de encontrar todos os erros de um programa é indecidível. Uma ferramenta de análise de fluxo de dados pode até ser projetada para alertar programadores sobre todas as possíveis partes do código com uma categoria específica de erros, porém se a maioria desses avisos forem falsos alarmes, os usuários não vão utilizar a ferramenta.

Por conta dessa complexidade, Aho et al. (2007) afirmam que os detectores práticos de erros frequentemente não são perfeitos (à prova de falhas ou *sound*) nem completos (*complete*). As abordagens tradicionais de detecção de vulnerabilidades estática geralmente codificam o conhecimento especializado como regras projetadas manualmente, com padrões e modelos de fluxo de dados, sua dependência de padrões predefinidos limita inerentemente a generalização e a cobertura para tipos de vulnerabilidades previamente não vistos ou em evolução.

Isso significa que a análise estática pode não encontrar todos os erros no programa, e nem todos os erros relatados têm a garantia de serem erros reais, e se as ferramentas relatassem todos os erros potenciais, o volume de falsos positivos tornaria as ferramentas inutilizáveis (AHO et al., 2007).

2.2.1.6 Análise estática baseada em regras

Em anos recentes, ferramentas de análise estática baseada em regras foram introduzidas. Complementando as ferramentas tradicionais, ao identificar previamente problemas durante o desenvolvimento pré-produção, reduzem significamente o custo e complexidade de *debugging* e manutenção (JIANG et al., 2025). Dos componentes mais utilizados, um dos mais relevantes são SemGrep e CodeQL (JIANG et al., 2025; HOU et al., 2025).

Formalmente, SemGrep é uma ferramenta de análise estática que suporta estruturas complexas e verificações básicas de fluxo de dados no código, permitindo inspeções sem execução para identificar vulnerabilidades de segurança, qualidade de código e violações a conformidade (HOU et al., 2025).

Sua gramática baseada em YAML mimetiza a sintaxe da linguagem alvo, reduzindo sua curva de aprendizado ao contrário de seu concorrente CodeQL (HOU et al., 2025), que possui sua própria gramática lógica, tratando o código como um banco de dados relacional, sendo possível realizar análises profundas porém custosa em tempo de aprendizado.

SemGrep converte código em uma árvore de sintaxe abstrata universal (UAST), aplicando um *pattern-matching* uniforme em mais de 30 linguagens (HOU et al., 2025). Por ser um projeto mantido ativamente e contar com uma plataforma pública na qual a comunidade compartilha regras prontas, o SemGrep facilita a adaptação de regras existentes e o desenvolvimento colaborativo.

Figura 7 – Exemplo de regra simplificada para detecção de falhas OSCI em Java.

```
1   patterns:
2       - pattern-inside: |
3           $FUNCDECL(..., $USER_DATA, ...) {...}
4       - pattern-either:
5           - pattern: |
6               $PB.command(..., $USER_DATA, ...)
7           - patterns:
8               - pattern-either:
9                   - pattern-inside: |
10                      $X = $USER_DATA; ...
11                  - pattern-inside: |
12                      $X = trim($USER_DATA); ...
13              - pattern: $PB.command(..., $X, ...);
```

Fonte: Adaptado de (JIANG et al., 2025).

Jiang et al. (2025) utilizam a regra da Figura 7 para ilustrar a utilidade prática do SemGrep: ela identifica, em código Java, uma falha de injeção de comandos no sistema operacional, do inglês *Operating System Command Injection* (OSCI).

Para que a busca seja flexível e rastrear fluxo de dados, o SemGrep utiliza dois recursos fundamentais:

(i) **Metavariáveis** (ex.: *$USER_DATA*, *$X*), a partir de um cifrão e nome da variável em letras maiúsculas. Essas variáveis são atribuídas quando SemGrep identifica um padrão que se encaixa, sendo "salvo" o valor na metavariável, consequentemente, se a metavariável é reutilizada na mesma regra, o SemGrep exigirá que o valor capturado seja exatamente o mesmo, o que permite *Data Flow*.

(ii) **Ellipsis/Curinga** (...), representando qualquer sequência de coisas. Assim independente da quantidade de argumentos em uma função, número de linhas de código entre

duas instruções, é possível omitir detalhes não importantes com (...), tornando SemGrep uma ferramenta abstraída.

Os predicados são as afirmações que procuram o código. *Tags* como *pattern* ou *pattern-inside* são predicados, com ***pattern*** sendo uma afirmação exata, como na linha 5, e ***pattern-inside*** define o contexto, não apontando a vulnerabilidade exata, mas exige que qualquer correspondência subsequente aconteça dentro da estrutura dele, como na linha 2.

A partir destes predicados, é possível combinar operações lógicas (*AND*, *OR*, *NOT*) sendo, respectivamente, *patterns*, *pattern-either*, *pattern-not*.

(i) O predicado ***patterns*** representa a lógica *AND* (E), para toda regra ou condição listada abaixo deste bloco devem ser verdadeiras simultaneamente. Como na linha 1, o bloco principal exige que o código esteja dentro da função (linha 2) **E** corresponda a um dos casos de injeção (linha 4).

(ii) ***pattern-either*** representa a lógica *OR* (OU), se o código corresponde a qualquer uma das condições aninhadas sob este predicado, a avaliação será verdadeira. Na linha 4, a regra procura um fluxo direto de *$USER_DATA* ou um fluxo indireto por atribuição.

(iii) ***pattern-not*** representa a lógica *NOT* (NÃO). Não presente no exemplo, porém usado para excluir falsos positivos, anulando caso a regra bater com a condição aninhada no predicado.

Com estes conhecimentos, é possível compreender como o SemGrep lida nativamente com falsos positivos. Predicados de exclusão, como *pattern-not* e *pattern-not-inside*, descartam ocorrências que já estão protegidas, por exemplo, o uso de um ponteiro que foi verificado contra `NULL` logo antes, enquanto *pattern-inside* restringe a busca ao contexto em que a falha de fato pode ocorrer. Assim, cada regra pode ser refinada de forma incremental, acrescentando exclusões para os falsos positivos observados, o que é explorado pelo *pipeline* proposto neste trabalho.

2.2.2 Vulnerabilidades de Linguagem

O termo Vulnerabilidade (*Vulnerability*) é definido como um conjunto de condições que permite que um invasor (atacante) viole uma política de segurança explícita ou implícita (SEACORD, 2013; Software Engineering Institute, 2016). Nem toda falha de segurança (*security flaw*) leva a uma vulnerabilidade (SEACORD, 2013).

Seacord (2013) explicam que para que uma falha torne um programa vulnerável a ataques, é necessário que os dados de entrada desse programa cruzem um limite de segurança (*security boundary*). Uma falha pode existir no código sem as pré-condições para ser explorada; por exemplo, se o programa apresentar um erro grave mas não possuir permissões para ser acessado localmente, ele não viola a política de segurança e não constitui uma vulnerabilidade ativa (SEACORD, 2013).

Uma vulnerabilidade pode existir mesmo sem que haja uma falha ou defeito no código (SEACORD, 2013). Como a segurança é um atributo de qualidade que muitas vezes precisa

ser balanceado com outros fatores (como desempenho e usabilidade), os projetistas de *software* podem decidir intencionalmente deixar um produto vulnerável a certas formas de exploração (SEACORD, 2013). Isso representação uma aceitação consciente do risco pelo projetista e não um erro de programação.

2.2.2.1 *Common Vulnerabilities and Exposures*

A Enumeração Comum de Vulnerabilidades e Exposições, mais popularmente conhecida do inglês *Common Vulnerabilities and Exposures* (CVE). Similarmente à CWEs, CVE atua como um dicionário, com foco em identificar, definir e catalogar vulnerabilidades de segurança cibernética que foram divulgadas publicamente (CVE Program, 2026).

CVE possui um único registro no seu catálogo para cada vulnerabilidade descoberta para uma versão específica de um *software*. O objetivo principal de se atribuir um CVE é permitir que profissionais de TI, ferramentas automatizadas e equipes de segurança cibernética saibam que estão se referindo exatamente ao mesmo problema (CVE Program, 2026).

Após a confirmação de uma vulnerabilidade, ela recebe um identificador único composto pelo ano de relato ou atribuição, seguido por um sequencial numérico. Parceiros como *National Vulnerability Database* (NVD) adicionam o registro com suas descrições, atribuindo um índice de severidade metrificado pela *Common Vulnerability Scoring System* (CVSS) e sua causa raiz proveniente da CWE (CVE Program, 2026).

2.2.2.2 *Common Weakness Enumeration*

A Enumeração de Fraquezas Comuns, mais popularmente conhecida do inglês *Common Weakness Enumeration* (CWE), é um dicionário formal e uma lista desenvolvida pela comunidade que cataloga fraquezas comuns de *software* e *hardware* (MITRE Corporation, 2026a).

Neste contexto, o termo fraqueza (*weakness*) é definido como uma condição em um componente de *software*, *firmware*, *hardware* ou serviço que, sob determinadas circunstâncias, pode contribuir para a introdução de vulnerabilidades (MITRE Corporation, 2026a). O projeto identifica, classifica e descreve esses problemas sob a nomenclatura de CWEs individuais (como, por exemplo, CWE-476 *Null Pointer Dereference*).

O propósito principal de se mapear essas fraquezas é permitir que desenvolvedores de *software*, projetistas de *hardware* e arquitetos de segurança as eliminem ainda na fase de desenvolvimento, antes da implantação (*deployment*), o que torna a correção muito mais fácil e barata.

O conteúdo de CWEs pode ser navegado através de diferentes visões, agrupando fraquezas para domínios específicos, como visões focadas estritamente em conceitos de Desenvolvimento de *Software*, organizando as falhas que surgem durante a programação),

Design de *Hardware* e Conceitos de Pesquisa, organizando as falhas por comportamentos (MITRE Corporation, 2026a).

O dicionário CWE fornece mapeamentos externos essenciais e atua como base para diversos outros recursos e guias de segurança fundamentais na indústria, como as listas **CWE Top 25**, **OWASP Top 10** e os **padrões de codificação segura do SEI CERT** (MITRE Corporation, 2026a; Software Engineering Institute, 2016). A lista de fraquezas é atualizada de três a quatro vezes por ano para adicionar ou aprimorar informações, e o dicionário é construído, em parte, tomando como base os problemas reportados nos registros de vulnerabilidades ativas do catálogo CVE, do inglês *Common Vulnerabilities and Exposures*.

Para o escopo deste trabalho, serão consideradas primariamente cinco vulnerabilidades presentes na lista oficial da CWE, todas são fraquezas relacionadas a falhas de memória. São elas:

- **CWE-401**: *Missing Release of Memory after Effective Lifetime*;
- **CWE-415**: *Double Free*;
- **CWE-416**: *Use After Free*;
- **CWE-457**: *Use of Uninitialized Variable*;
- **CWE-476**: *Null Pointer Dereference*.

2.2.2.3 CWE-401

A CWE-401, chamada de Vazamento de Memória, do inglês *Missing Release of Memory after Effective Lifetime* ou *Memory Leak*, ocorre quando um programa aloca memória, mas falha em rastreá-la ou liberá-la adequadamente após ela não ser mais necessária (MITRE Corporation, 2026b). Isso torna o bloco de memória indisponível para realocação ou reúso.

De acordo com MITRE Corporation (2026b), é frequentemente causada por caminhos de execução, como condições de erro, dados malformados ou sessões interrompidas abruptamente, onde o código falha em executar a rotina de limpeza. Também surge da confusão sobre qual parte do programa é responsável por realizar o *free* em linguagens de gerenciamento manual, como C.

Embora normalmente resulte em problemas gerais de confiabilidade do *software*, se um invasor conseguir desencadear repetidamente esse vazamento de forma intencional, ele poderá esgotar a memória do sistema (MITRE Corporation, 2026b). Consequentemente leva a uma Negação de Serviço, em inglês *Denial of Service* (DoS) por consumo excessivo de resursos (CPU ou memória) ou travamentos.

A melhor forma é utilizar linguagens, bibliotecas ou *frameworks* que forneçam gerenciamento automático de memória (como *garbage collectors*) (MITRE Corporation, 2026b).

Linguagens como C, contudo, não oferecem esse gerenciamento de forma nativa. A adoção de bibliotecas externas para suprir essa falta exige cautela do projetista, que deve ponderar o custo de desempenho (*overhead*), o risco de introdução de novas vulnerabilidades pela própria biblioteca e o aumento no esforço de análise de segurança do sistema.

2.2.2.4 CWE-415

A CWE-415, chamada de Liberação Dupla, do inglês *Double Free*, ocorre quando o produto chama a função de liberação (como `free()`) duas vezes no mesmo endereço de memória (MITRE Corporation, 2026c).

Semelhante ao vazamento de memória (2.2.2.3), costuma ser resultado de condições de erro não tratadas corretamente ou confusão lógica sobre a responsabilidade de limpar a memória, especialmente quando ponteiros são usados de forma global ou espalhados por centenas de linhas e múltiplos arquivos (MITRE Corporation, 2026c).

Chamar a função `free()` de forma dupla corrompe as estruturas de dados de gerenciamento de memória do sistema. O programa pode travar, ou, pior, fazer com que duas chamadas futuras da função `malloc()` retornem exatamente o mesmo ponteiro (MITRE Corporation, 2026c). Se o invasor controlar os dados inseridos nessa memória "duplamente alocada", ele ganha uma condição conhecida como *write-what-where* e pode realizar ataques de *buffer overflow*, chegando a **executar código arbitrário** (MITRE Corporation, 2026c).

Para garantir que cada alocação seja liberada apenas uma vez, uma técnica prática é definir o ponteiro como `NULL` imediatamente após o primeiro `free`, garantindo que não possa ser liberado novamente por engano (MITRE Corporation, 2026c).

2.2.2.5 CWE-416

A CWE-416, chamada de Uso Após Liberação, do inglês *Use After Free* (UAF), ocorre quando o programa continua a utilizar ou referenciar um ponteiro para a memória que já foi liberada (MITRE Corporation, 2026d). Como a memória já foi devolvida, ela pode ter sido realocada e preenchida com dados novos; logo, as operações realizadas com o ponteiro original interagem acidentalmente com os dados da nova alocação (MITRE Corporation, 2026d).

Frequentemente resulta de outras fraquezas primárias, como, em concorrência, condições de corrida, manipulação inadequada de erros ou apenas liberação precoce por falha lógica (MITRE Corporation, 2026d).

É possível causar alteração não intencional de memória, corrompendo dados válidos, vazamento de informações confidenciais, como permissão de leitura indevida, e DoS por travamento (MITRE Corporation, 2026d). Além disso, se o invasor conseguir inserir dados maliciosos logo após o ponteiro ser liberado, é possível **executar códigos ou comandos arbitrários** assumindo o controle da execução (MITRE Corporation, 2026d).

Além do uso de gerenciamento automático, usar o conceito visto em CWE-415 (2.2.2.4), definindo os ponteiros como `NULL` imediatamente após serem liberados. Se houver uma falha que tente reutilizar esse ponteiro depois disso, ocorrerá um travamento (Desreferenciamento de Nulo), mas isso elimina a possibilidade crítica de execução de código malicioso (MITRE Corporation, 2026c).

2.2.2.6 CWE-457

A CWE-457, chamada de Uso de Variável Não Inicializada, do inglês *Use of Uninitialized Variable*, ocorre quando o código usa uma variável que não recebeu um valor inicial (MITRE Corporation, 2026e). Em linguagens como C, variáveis armazenadas na pilha (*stack*) não são limpas por padrão e conterão lixo de memória deixado por chamadas de funções anteriores.

Segundo MITRE Corporation (2026e), tipicamente ocorre por erros tipográficos no código ou porque um fluxo lógico (como `switch` ou `if/else`) falhou em cobrir todos os casos e não atribuiu valor à variável antes de ela ser utilizada.

Essa fraqueza pode gerar comportamentos totalmente imprevisíveis, corromper o fluxo de controle esperado do programa ou causar DoS. Em cenários críticos, um invasor pode influenciar os dados residuais na pilha (pré-inicializando o lixo intencionalmente) para contornar checagens de senha, burlar travas lógicas ou **executar código** (MITRE Corporation, 2026e). O problema se agrava com *strings*, pois funções contam com um terminador nulo que pode não existir no lixo residual.

Sempre garantir explicitamente que variáveis essenciais recebam um valor padrão aceitável no momento de declaração (MITRE Corporation, 2026e). É fortemente recomendado configurar e usar ferramentas de compilação em modos rigorosos, pelos compiladores moderrnos costumarem emitir alertas consistentes quando variáveis são lidas sem serem inicializadas (MITRE Corporation, 2026e).

2.2.2.7 CWE-476

A CWE-476, chamada de Desreferenciamento de Ponteiro Nulo, do inglês *Null Pointer Dereference*, ocorre quando o código tenta desreferenciar, acessar o conteúdo ou método apontado, um ponteiro sob a suposição de que ele é válido, mas seu valor real é `NULL` (MITRE Corporation, 2026f).

Muitas funções de busca ou resolução de rede (por exemplo: `gethostbyaddr`) retornam nulo quando falham, e os desenvolvedores se esquecem de checar o retorno (*Unchecked Return Value*) antes de usar o resultado do ponteiro (MITRE Corporation, 2026f). Também pode ser consequência de variáveis não inicializadas ou concorrência em sistemas assíncronos.

Segundo MITRE Corporation (2026f), a consequência geralmente é o **travamento completo do processo** (DoS), sendo muito difícil que o programa se recupere para

um estado seguro de funcionamento, mesmo com tratamentos de exceção. Em raras circunstâncias, como quando `NULL` equivale ao endereço de memória literal `0x00` e o código privilegiado pode acessá-lo, um invasor pode ler/escrever na memória e **executar códigos** (MITRE Corporation, 2026f).

Validar e checar estritamente resultados de todas as funções, confirmando que o valor não é nulo antes de utilizá-lo. Inicializar variáveis com valores padrões também previnem essa situação (MITRE Corporation, 2026f).

2.2.3 Linguagem Natural

Um sistema formal amplamente utilizado para modelar a estrutura constituinte em linguagens naturais é a Gramática Livre de Contexto (*Context-Free Grammar* - CFG). Também conhecidas como gramáticas de estrutura de frase (*phrase-structure grammars*), as CFGs utilizam um formalismo que é equivalente à Forma de Backus-Naur (BNF), padrão universal para a especificação da sintaxe em computação (JURAFSKY; MARTIN, 2026).

Uma CFG consiste em um conjunto de regras ou produções, onde cada uma expressa como os símbolos podem ser ordenados e agrupados, e um léxico de palavras e símbolos. Tal estrutura define uma linguagem formal, na qual existe uma separação estrita: sentenças que podem ser derivadas pelas regras são consideradas gramaticais, enquanto as que não podem são denominadas agramaticais (JURAFSKY; MARTIN, 2026).

Contudo, essa distinção rígida é uma característica das gramáticas formais e serve apenas como um modelo simplificado das linguagens naturais. Diferente das linguagens de programação, a validade e o sentido em linguagem natural dependem intrinsecamente do contexto. Na linguística computacional, o uso desses modelos para capturar tal complexidade é fundamentado na gramática generativa, visto que a linguagem passa a ser definida pelo conjunto de possíveis 'geradas' por suas regras gramaticais (JURAFSKY; MARTIN, 2026).

2.2.3.1 Processamento de Linguagem Natural

O Processamento de Linguagem Natural, do inglês *Natural Language Processing* (NLP), tem de objetivo fundamental capacitar os sistemas computacionais a processar, armazenar, compreender e gerar a linguagem humana, permitindo que as máquinas se comuniquem com sucesso e realizem tarefas inferenciais complexas (JURAFSKY; MARTIN, 2026).

Os autores pontuam que o problema da compreensão da linguagem é consideravelmente complexo, pois não se restringe apenas ao entendimento da estrutura sintática das sentenças, mas exige uma profunda compreensão da semântica, do contexto e do assunto abordado.

O campo de NLP progrediu através de diferentes abordagens de resolução, a abordagem mais relevante para este trabalho é o Aprendizado Profundo (*Deep Learning*). Baseado

na arquitetura *Transformer*, esse paradigma mudou o foco da engenharia manual de características para a aprendizagem de representação (*representation learning*), onde os modelos aprendem automaticamente vetores de significado contínuos (*embeddings* contextuais) operando em vastas quantidades de texto não rotulado, mediante o pré-treinamento autossupervisionado (JURAFSKY; MARTIN, 2026).

O NLP é dividido em tarefas de Compreensão de Linguagem Natural (*Natural Language Understanding* - NLU), focadas em extrair significado, e Geração de Linguagem Natural (*Natural Language Generation* - NLG), focadas na produção de texto coerente (TUNSTALL; WERRA; WOLF, 2022).

Para modelos mais utilizados de LLMs, o foco inerente desses modelos é NLG. Graças à capacidade de aprendizado em contexto (*in-context learning*) guiado por *prompts*, esses modelos utilizam a sua capacidade de geração (NLG) para resolver, de forma indireta, os problemas de compreensão (NLU) (TUNSTALL; WERRA; WOLF, 2022; JURAFSKY; MARTIN, 2026).

2.2.4 Arquitetura *Transformer*

A arquitetura *Transformer*, proposta por Vaswani et al. (2017) inicialmente para tarefas como a tradução automática, é um modelo de transdução de sequências que dispensa o uso total de Redes Neurais Recorrentes (*Recurrent Neural Networks* RNNs) e convolucionais (*Convolucional Neural Networks* - CNNs). Ao invés disso, ela se baseia exclusivamente em mecanismos de atenção para capturar dependências globais entre as sequências de entrada e saída.

A arquitetura segue uma estrutura de **Codificador-Decodificador** (*Encoder-Decoder*).

- **Codificador (*Encoder*)**: Segundo Vaswani et al. (2017), o codificador tem a função de converter uma sequência de *tokens* de entrada em uma sequência de representações contínuas (*embeddings* ou estados ocultos contextuais). Composto por uma pilha de camadas idênticas de $N = 6$. Cada camada possui duas subcamadas principais:

  1. Mecanismo de Autoatenção de Múltiplas Cabeças (*Multi-Head Self-Attention*).
  2. Rede Neural *Feed-Forward* totalmente Conectada, aplicada de forma independente a cada posição (*Position-Wise fully Connected Feed-Forward Network*).

  Em torno de cada uma das subcamadas, o modelo emprega uma conexão residual (*skip/residual connection*) seguida de uma normalização de camada (*layer normalization*) (VASWANI et al., 2017; TUNSTALL; WERRA; WOLF, 2022).

  Esses modelos convertem uma sequência de texto de entrada em uma representação numérica, sendo muito eficientes para tarefas como classificação de texto ou reconhecimento de entidades nomeadas. A representação calculada para cada *token* nessa

arquitetura depende tanto do contexto à esquerda (antes do *token*) quanto à direita (depois do *token*); esse mecanismo é geralmente denominado atenção bidirecional (TUNSTALL; WERRA; WOLF, 2022).

- **Decodificador (*Decoder*)**: O decodificador utiliza as representações contínuas geradas pelo codificador para produzir iterativamente a sequência de saída, gerando um símbolo (*token*) de cada vez, com uma propriedade autorregressiva, ou seja, consumindo os símbolos gerados anteriormente como entrada adicional (VASWANI et al., 2017; TUNSTALL; WERRA; WOLF, 2022).

  Assim como o codificador, é composto por uma pilha de $N = 6$ camadas idênticas. Além das camadas presentes no codificador, o decodificador introduz uma terceira subcamada e aplica uma modificação vital na sua autoatenção:

  1. Autoatenção Mascarada de Múltiplas Cabeças (*Masked Multi-Head Attention*): A autoatenção do decodificador é mascarada (através da atribuição de valores $-\infty$ para conexões ilegais) para impedir que uma posição acesse informações de *tokens* futuros (*leftward information flow*), garantindo que a previsão do próximo *token* dependa apenas das saídas já conhecidas (VASWANI et al., 2017; TUNSTALL; WERRA; WOLF, 2022).
  2. Atenção Codificador-Decodificador (*Encoder-Decoder Attention* ou *Cross-Attention*): Esta subcamada realiza a atenção sobre a saída da pilha do codificador. Nela, as consultas vêm da camada anterior do decodificador, enquanto as chaves e valores vêm da saída do codificador, permitindo que o modelo relacione *tokens* de ambas as sequências (VASWANI et al., 2017; TUNSTALL; WERRA; WOLF, 2022; JURAFSKY; MARTIN, 2026).
  3. Rede Neural *Feed-Forward* orientada à posição.

  A partir disso, dada uma entrada de texto, esses modelos completam a sequência prevendo iterativamente a palavra subsequente mais provável.

A função de atenção no *Transformer* mapeia um vetor de Consulta (*Query* - Q), um conjunto de vetores Chave (*Key* - K) e vetores Valor (*Value* - V) para produzir uma saída (VASWANI et al., 2017; TUNSTALL; WERRA; WOLF, 2022).

A Atenção de Produto Escalar Escalado (*Scaled Dot-Product Attention*) é calculada pela seguinte fórmula:

$$Attention(Q, K, V) = softmax\left(\frac{QK^T}{\sqrt{d_k}}\right)V \tag{2.1}$$

onde d_k é a dimensão dos vetores Chave. Essa operação permite que cada *token* "preste atenção" em todos os outros *tokens* da sequência, ponderando sua importância relativa. O fator de escala $\sqrt{d_k}$ é utilizado para estabilizar os gradientes durante treinamento.

Essa fórmula é a origem do custo quadrático mencionado na Introdução, no Capítulo 1. Para uma sequência de n *tokens*, as matrizes Q e K têm dimensão $n \times d_k$, e o produto QK^T resulta em uma matriz $n \times n$ com um peso para cada par de *tokens*, sendo cada peso um produto escalar entre vetores de dimensão d_k.

Por isso, Vaswani et al. (2017, Tabela 1) atribuem à camada de autoatenção uma complexidade de $O(n^2 \cdot d)$ por camada, contra $O(n \cdot d^2)$ de uma camada recorrente, em que d é a dimensão das representações.

Os próprios autores observam que a autoatenção é mais rápida que a recorrência apenas enquanto n é menor que d, situação comum nas frases usadas em tradução automática, mas que deixa de valer para entradas longas, como arquivos de código-fonte extensos. Além do tempo, a matriz $n \times n$ precisa ser armazenada em cada cabeça de atenção, o que torna também o consumo de memória quadrático em relação ao tamanho da sequência (DAO et al., 2022).

Esses modelos não aplicam a atenção apenas uma vez. Em vez de realizar uma única função de atenção com dimensões globais, a arquitetura projeta as Consultas, Chaves e Valores h vezes de forma linear e independente. Eles realizam h projeções lineares independentes de Q, K e V. Espressada por:

$$MultiHead(Q, K, V) = Concat(head_1, ..., head_h)W^O \tag{2.2}$$

onde $head_i = Attention(QW_i^Q, KW_i^K, VW_i^V)$. Isso permite que o modelo atenda simultaneamente a informações de diferentes subespaços de representação em várias posições do texto (VASWANI et al., 2017).

Dado que o *Transformer* não contém recorrência ou convolução, o modelo nativamente desconhece a ordem de sequência. Para solucionar isso, Vaswani et al. (2017) propuseram injetar informações sobre a posição relativa ou absoluta dos *tokens* na sequência através de Codificações Posicionais (*Positional Encodings*) (VASWANI et al., 2017). Esses vetores de posição possuem a mesma dimensão que os *embeddings* dos *tokens* e são inseridos nas bases das pilhas do codificador e do decodificador.

No final da pilha do decodificador, o vetor de representação contínua é passado por uma transformação linear (*unembedding matrix*) e, em seguida, por uma função *softmax* para converter as pontuações (*logits*) em probabilidades normalizadas sobre o vocabulário, gerando a previsão do próximo *token* (VASWANI et al., 2017).

2.2.4.1 Modelos de Linguagens de Grande Escala

Os Modelos de Linguagem de Grande Escala, do inglês *Large Language Models* (LLMs), são sistemas computacionais baseados em redes neurais profundas, quase exclusivamente utilizando a arquitetura *Transformer*, projetados para prever, gerar e interagir utilizando Linguagem Natural (2.2.3) (JURAFSKY; MARTIN, 2026).

Segundo Jurafsky e Martin (2026), uma LLM é um sistema probabilístico que, dado um contexto ou prefixo de palavras, atribui uma distribuição de probabilidade aos possíveis próximos símbolos (*tokens*) do vocabulário.

Existem três configurações principais de *Transformers* (codificadores, decodificadores e codificadores-decodificadores), os LLMs generativos modernos (como a família GPT, Claude, Lhama, etc.) utilizam a arquitetura baseada estritamente em Decodificadores (*Decoders*). Pela natureza de gerar iterativamente o próximo *token* por vez e consumir a própria saída como entrada para o passo seguinte, esse processo é denominado geração causal ou autorregressiva (*causal or autorregressive generation*) (JURAFSKY; MARTIN, 2026).

A ideia central, proposta por Jurafsky e Martin (2026), que torna os LLMs possíveis é o pré-treinamento. Os modelos aprendem conhecimentos profundos sobre a linguagem, o contexto e o mundo simplesmente sendo ensinados de forma iterativa a prever a próxima palavra em *corpora* gigantescos de texto.

Esse processo é autossupervisionado (*self-supervised*), pois a sequência natural de palavras serve como sua própria supervisão. O algoritmo ajusta bilhões de parâmetros da rede (pesos de atenção e *feed-forward*) minimizando a função de perda de entropia cruzada (*cross-entropy loss*), que penaliza o modelo quando ele atribui uma probabilidade baixa à palavra que de fato é a correta no texto (JURAFSKY; MARTIN, 2026).

Após o pré-treinamento, qualquer tarefa de Processamento de Linguagem Natural (2.2.3.1) pode ser modelada como uma geração condicional guiada por um *prompt* (JURAFSKY; MARTIN, 2026). Sua capacidade de aprendizado em contexto (*in-context learning*) permite que LLMs aprendam a executar novas tarefas durante a fase de inferência (quando estão apenas gerando texto) a partir das instruções ou demonstrações contidas no *prompt*, sem que haja nenhuma atualização de parâmetros baseada em gradientes no modelo subjacente (JURAFSKY; MARTIN, 2026).

Um modelo apenas pré-treinamento tende a simplesmente dar continuidade ao texto de forma passiva em vez de responder à intenção do usuário, além de ser suscetível a gerar alucinações (*hallucinations*) ou saída inseguras (JURAFSKY; MARTIN, 2026). Para torná-los assistentes úteis, os LLMs passam por duas fases cruciais de Pós-Treinamento (*Post-training*).

Primeiro, o modelo é submetido a um ajuste fino (*finetuning*) utilizando um conjunto de dados contendo pares de instruções e as respostas desejadas. Ensinando o modelo não apenas a resolver tarefas, mas atua como um meta-aprendizado para que ele se torne fundamentalmente melhor em seguir instruções de modo geral (JURAFSKY; MARTIN, 2026).

Para garantir que o modelo seja útil e inofensivo (*helpful and non-harmful*), técnicas de Aprendizado por Reforço (*Rein-forcement Learning* - RL) ou Otimização Direta de Preferências (*Direct Preference Optimization*) são utilizadas. O modelo é treinado para que

suas saídas maximizem uma recompensa alinhada com os valores e preferências humanas, penalizando respostas indesejadas, rudes ou incorretas (JURAFSKY; MARTIN, 2026).

2.2.4.2 Agentes e Sistemas Multi-Agentes

Um agente é definido como qualquer entidade capaz de perceber o seu ambiente através de sensores e agir sobre esse ambiente por meio de atuadores (RUSSELL; NORVIG, 2020). O comportamento lógico dessa entidade é matematicamente descrito por uma função de agente, que mapeia a sequência completa de percepções recebidas para a escolha de uma ação correspondente (RUSSELL; NORVIG, 2020).

O objetivo no desenvolvimento dessas soluções é a construção de um agente racional, ou seja, aquele que seleciona ações com a expectativa de maximizar sua medida de desempenho, baseando-se nas evidências do ambiente e em seu conhecimento embutido (RUSSELL; NORVIG, 2020).

A complexidade de determinados problemas, contudo, exige soluções que transcendem a capacidade de um único agente. Nestes casos, adota-se a arquitetura de Sistemas Multi-Agentes (RUSSELL; NORVIG, 2020). Os desafios de *design* em ambiente multi-agentes diferem significativamente dos ambientes isolados, uma vez que, em cenários cooperativos, a comunicação e a coordenação entre as entidades emergem como comportamentos racionais necessários para evitar redundâncias e atingir o objetivo de forma eficiente (RUSSELL; NORVIG, 2020).

Com a consolidação dos Modelos de Linguagem de Larga Escala (LLMs), o paradigma baseado em agentes ganhou nova capacidade operacional. Os LLMs passaram a atuar como o núcleo de decisão dos agentes: em ferramentas como o RepoAudit, um agente baseado em LLM explora de forma autônoma um repositório de código, decidindo quais funções analisar a seguir e registrando o que já descobriu em uma memória própria (GUO et al., 2025).

Os sistemas multi-agentes levam essa ideia adiante, decompondo uma tarefa complexa entre agentes coordenados, cada um responsável por uma subtarefa localizada, o que também oferece um meio de integrar ferramentas externas e fluxos de trabalho estruturados.

Em um *framework* multi-agente fundamentado em LLMs, o mesmo modelo de base pode ser usado por vários agentes, que se diferenciam pelas instruções e metas específicas fornecidas a cada um no *prompt*.

Os trabalhos analisados indicam dois benefícios dessa divisão. O primeiro diz respeito à janela de contexto: como cada agente trata apenas uma parte do problema, nenhum deles precisa receber a base de código inteira; o RepoAudit, por exemplo, analisa uma função por vez e recupera sob demanda apenas os trechos necessários (GUO et al., 2025).

O segundo diz respeito às alucinações: o resultado de um agente pode ser conferido por outro componente antes de ser aceito, como no módulo validador do RepoAudit, que verifica os fatos de fluxo de dados levantados pelo LLM para reduzir falsos positivos (GUO

et al., 2025), e no agente de triagem do KNighter, que descarta alarmes falsos produzidos pelos verificadores gerados (YANG et al., 2025).

2.2.5 Métricas de Avaliação

As métricas de avaliação para uma ferramenta de análise estática funcional requer métricas que permitam analisar não apenas a acurácia geral, mas o equilíbrio entre erros de falso positivo e falso negativo.

Neste trabalho, serão utilizadas diferentes métodos de avaliação, se dividindo em Validade Gramatical (2.2.5.2), Validade Funcional (2.2.5.3), Validação em *Dataset* (2.2.5.4), Validação no mundo real (2.2.5.5), Custo (2.2.5.6).

2.2.5.1 Juliet Test Suite

O *Juliet Test Suite* é uma coleção de programas escritos em C/C++ e Java, contendo casos de teste sintéticos, que foram desenvolvidas como exemplos de vulnerabilidades (NSA Center for Assured Software, 2017).

A coleção foi desenvolvida por NSA Center for Assured Software (2017), um projeto de domínio público. A versão mais recente 1.3 para C/C++ possui mais de 64 mil casos de teste espalhados em mais de 100 mil arquivos. O *dataset* não foca em problemas lógicos ou de arquitetura geral de *software*, mas em vulnerabilidades de código categorizadas pelo sistema CWE (2.2.2.2).

O propósito central é servir como um "campo de provas" padronizado para ferramentas de análise de código, como analisadores estáticos (do inglês *Static Application Security Testing* - SAST). Esse conjunto será utilizado para analisar todos os CWEs selecionados para este trabalho, analisando a eficácia das regras produzidas.

2.2.5.2 Validade Gramatical

Determina se uma regra é identificada com sucesso pela ferramenta de análise estática sem gerar erros de sintaxe.

Para avaliar a validade de sua gramática, cada regra é aplicada na ferramenta para avaliar um código teste, avaliando somente se a ferramenta reporta ou não algum erro de sintaxe na própria regra durante a execução.

Sendo analisado também quais regras geram *loops* de correção, quais o agente de correção não foi capaz de corrigir.

2.2.5.3 Validade Funcional

Define a precisão da regra sobre distinguir corretamente um código defeituoso e corrigido. Para realizar essa avaliação, cada regra introduzida à ferramenta, é avaliado os relatórios gerados a partir dela sobre o código gerador da regra (defeituoso e corrigido).

Analisando a verificação em ambos casos, é identificado o número de relatos no código com *bugs* ($X_{identificados}$) e no código corrigido ($X_{corrigidos}$), sendo validado somente nos casos em que no código corrigido não seja identificado nenhum relatório ($X_{corrigidos} = 0$) e no código defeituoso todos os N casos presentes ($X_{identificados} >= N$).

2.2.5.4 Validação em *Dataset*

A métrica mais intuitiva para avaliar um modelo é a Acurácia (*Accuracy*), medindo a proporção de previsões corretas em relação ao total de previsões. Porém, como em casos de aplicação de mundo real muitos códigos não estão categorizados e corretamente identificados, é perigosamente enganosa a sua métrica neste escopo.

A alternativa é o **F1-Score**, sendo uma métrica utilizada para avaliar o desempenho de modelos de classificação. Cada previsão feita pelo modelo cai em uma das quatro categorias:

- **Verdadeiros Positivos** (*True Positive* - TP);
- **Falsos Positivos** (*False Positive* - FP);
- **Falsos Negativos** (*False Negative* - FN);
- **Verdadeiros Negativos** (*True Negative* - TN).

A **Precisão** (*Precision* - *P*) indica a proporção de exemplos positivos que foram corretamente identificados. No contexto desse trabalho, representa a proporção de trechos de códigos classificados que realmente eram *bugs*. É especialmente importante sua corretude quando o custo de falsos positivos é alto, causando a inutilização da ferramenta (AHO et al., 2007).

$$Precision = \frac{TP}{TP + FP} \tag{2.3}$$

A **Revocação ou Sensibilidade** (*Recall* - R) mede a capacidade do modelo de encontrar todas as instâncias positivas reais. Neste caso, indica quantas das vulnerabilidades foram realmente identificadas pelo modelo.

$$Recall = \frac{TP}{TP + FN} \tag{2.4}$$

Avaliou-se especificamente se a ferramenta foi capaz de apontar o alerta diretamente nos pontos do programa já rotulados e conhecidos como vulneráveis.

A métrica **F1-Score** representa a média harmônica entre a Precisão e Revocação, sendo particularmente útil quando se busca um equilíbrio entre as duas. Sua fórmula é calculada por:

$$F1\text{-}Score = 2 \times \frac{Precision \times Recall}{Precision + Recall} \tag{2.5}$$

No cenário da Análise Estática, o F1-Score reflete competentemente o *trade-off* entre as identificações corretas e falhas.

2.2.5.5 Validação no mundo real

Na aplicação para projetos de código aberto, é desconhecido o número de vulnerabilidades. A partir desse conhecimento, este trabalho adota, para a aplicação sobre código real, a **Taxa de Falsas Descobertas Amostradas** (do inglês *Sampled False Discovery Rate* - SFDR).

Na execução da ferramenta em projetos *open-source* sem rótulos conhecidos, é extraído o **Número de Relatórios** ($\#Relatorios$) gerados, o **Número de Arquivos** ($\#Arquivos$) afetados, contendo pelo menos um aviso e **Número de Falsos Positivos** ($\#FPs$), instâncias incorretamente relatadas como vulnerabilidades. Baseado nessas categorias, estimamos o SFDR como:

$$SFDR = \frac{\#FPs}{\#Relatorios} \tag{2.6}$$

A partir desses dados, é possível avaliar o quão eficiente será a ferramenta em problemas no mundo real.

2.2.5.6 Custo

Para analisar de forma adequada o custo gerado pela geração e análise, este trabalho utiliza as mesmas avaliações adotadas na área. Será analisado o número de consumo de *tokens* processados nas entradas e saídas para cada projeto, bem como a medição do tempo exato de execução que a ferramenta levou para analisar o repositório.

2.3 Trabalhos correlatos

Os três trabalhos apresentados a seguir foram selecionados por enfrentarem diretamente o mesmo problema central: as limitações da análise estática tradicional na detecção de vulnerabilidades, buscando superá-las com o apoio de LLMs.

Cada um deles atribui à LLM um papel diferente: sintetizar verificadores para um analisador existente (YANG et al., 2025), gerar regras para o SemGrep (HOU et al., 2025) ou auditar diretamente o repositório por meio de um agente autônomo (GUO et al., 2025).

2.3.1 Trabalho 1: *KNighter: Transforming Static Analysis with LLM-Synthesized Checkers* (YANG et al., 2025)

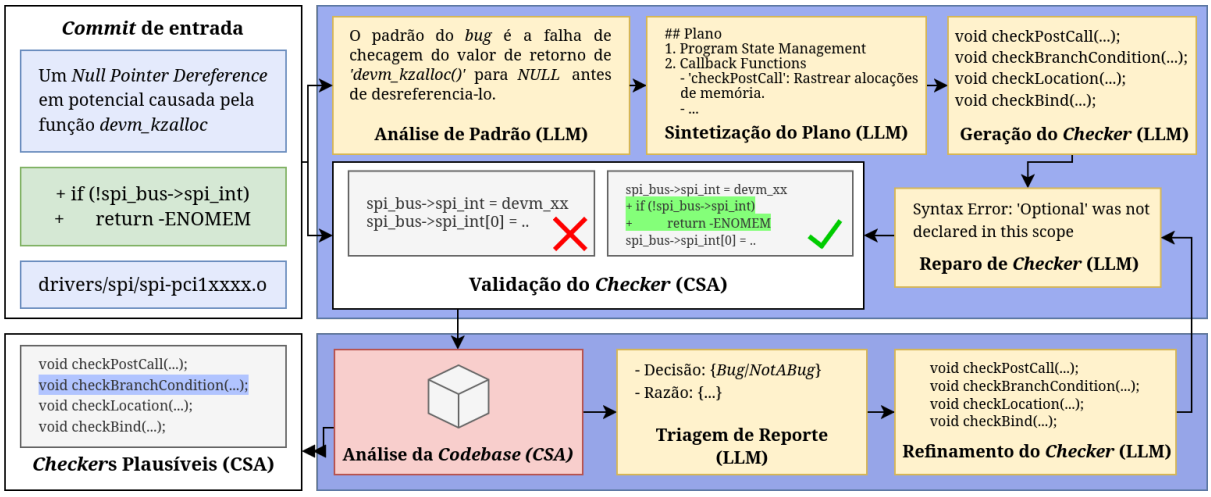
O trabalho de Yang et al. (2025) é considerado o estudo pioneiro para a área de Analisadores Estáticos Automatizados. Publicado em SOSP 25 *(ACM SIGOPS 31st Symposium on Operating Systems Principles)*, em Seul, República da Coreia. KNighter foi o primeiro sistema de geração de analisadores estáticos totalmente automatizado (YANG et al., 2025).

Os autores buscam resolver o problema principal com métodos de análise tradicional. Apesar da análise estática ser o método mais eficiente pela sua falta de execução de código, para gerenciamento de sistemas de larga escala, esses métodos falham na falta de identificar diferentes padrões de bugs e gerenciamento de bases enormes de código (YANG et al., 2025). A figura 1 mostra a motivação que os autores tinham sobre analisadores automatizados.

Motivado pelas limitações expostas, o trabalho propõe um *framework* voltado à extração de padrões a partir de histórico de *commits*. Como exemplo empírico, a identificação de chamadas à função `devm_kzalloc` desacompanhadas de verificação de nulidade configura uma heurística válida para a detecção da vulnerabilidade *Null Pointer Dereference* (CWE-476) (YANG et al., 2025).

Com um *commit* como entrada, KNighter retorna como saída um analisador gerado para *Clang Static Analyser* (CSA). Sendo um verificador válido aquele que identifica o código pré alteração do *commit* como *bug* e o código corrigido como correto (YANG et al., 2025).

Figura 8 – *Overview* do KNighter



Fonte: Adaptado para o português para melhor compreensão (YANG et al., 2025).

O motor principal do framework é *Clang Static Analyser* (CSA), Yang et al. (2025) explica que CSA opera a partir de uma execução simbólica *path-sensitive*, construindo

uma representação interna chamada *ExplodedGraph*. CSA é modulável pela sua construção a partir de *checkers*, sendo eles, pequenos componentes especializados, montados a partir de um *template* (YANG et al., 2025).

Na figura 8 mostra como o KNighter funciona em duas fases: sintetização de *checkers*, o projeto analisa o *patch* de entrada para identificar padrões de *bugs*, sintetiza, a partir do conteúdo identificado, um plano de detecção e implementa um CSA *checker* (YANG et al., 2025). Se ocorre qualquer erro de compilação, é encaminhado para um agente de sintaxe que automaticamente repara o *checker* a partir das mensagens de erro (YANG et al., 2025).

No que tange à implementação do trabalho, a metodologia descrita por Yang et al. (2025) fundamenta-se na coleta de *commits*, viabilizando uma análise comparativa e estrutural entre versões vulneráveis de código-fonte e suas respectivas correções. Foram coletados 10 tipos de CWEs, criando para cada CWE um respectivo CSA *checker*.

Além dessa coleção, foram preparados 3 tipos de exemplos de *checkers* para aprendizado *in-context*, lidando com os respectivos CWEs: *Null Pointer Dereference* (CWE-476), *Use of Uninitialized Variable* (CWE-457) e *Double Free* (CWE-415) (YANG et al., 2025). Além desses exemplos, os autores identificaram repetições de atividades que cada *checker* reutiliza, então separaram em 9 *sub-checkers* para poderem serem reutilizados em outros verificadores.

Para a avaliação de cada *checker*, é analisado sua eficácia para o *bug* do *commit* analisado e reconhecer sua correção. No repositório original do *patch*, o analisador realiza uma varredura integral na versão do código imediatamente à correção, quantificando o total de vulnerabilidades identificadas (N_{buggy}).

Em seguida, uma nova varredura é executada na base atualizada para contabilizar as vulnerabilidades remanescentes (N_{patched}), viabilizando assim a validação da eficácia do verificador. Um *checker* é considerado válido se $N_{\text{buggy}} > N_{\text{patched}}$ e $N_{\text{patched}} < T_{\text{valid}}$, onde T_{valid} é um valor limite (padrão 50) (YANG et al., 2025).

Apesar de seu forte pioneirismo, Yang et al. (2025) analisa suas falhas com seu projeto, com 36,06% dos *commits* não sendo possível gerar um analisador a partir disso, com sua maioria falhando por implementações incorretas, com o problema comum são otimizações realizadas pelo respectivo compilador (como strcp e memset), impedindo que o *checker* lidasse com essas chamadas.

Além disso, notaram limitações relacionadas a *Buffer Overflow* e *Use of Uninitialized Variable*. Os autores atribuem essa dificuldade a dois fatores principais. O primeiro é a limitação inerente da análise estática em determinar valores precisos, principalmente quando é preciso determinar limites de *buffers*. O segundo é a dificuldade para analisar códigos *multi-thread*, como no gerenciamento correto de *locks* (YANG et al., 2025).

KNighter relata dentre 37 *checkers* plausíveis, foram relatados 92 novos *bugs*, que depois de uma inspeção manual, 32,2% foram falsos positivos (YANG et al., 2025). Sendo

o principal erro que envolve os analisadores com seu padrão correto e regras para *matching* corretos, porém o *checker* falha em gerenciar *triggers* ou a condição do estado corretamente (como identificar um ponteiro já verificado antes de seu uso) (YANG et al., 2025).

Para o presente trabalho, a contribuição de Yang et al. (2025) é insubstituível no ponto de vista conceitual: a automatização para um sistema de análise estática, gerenciamento de mais de um agente para refinamento e correção, cobrindo CWEs relevantes adotados neste TCC.

No entanto, a ferramenta auxiliar difere: enquanto Yang et al. (2025) opera gerenciando regras para CSA, este trabalho opera exclusivamente com SemGrep, com suas regras de inclusão e exclusão lógica auxilia para evitar falsos positivos, que foi um defeito crítico em KNighter. Além disso, KNighter utiliza somente *commits* para seu treinamento, o que limita sua detecção pelo simples fato de existirem outras vulnerabilidades que não se encaixam nos *patches* já corrigidos; para contribuir na solução deste problema, este trabalho recorre ao *dataset* de NSA Center for Assured Software (2017).

2.3.2 Trabalho 2: *Generation, Migration and Optimization of Cross-Language Static-Analysis Rules Based on Large Language Models* (HOU et al., 2025)

O trabalho de Hou et al. (2025), publicado no IEEE International Conference on Software e Quality, Reliability and Security (QRS) em 2025, representa um dos trabalhos que compõem o atual estado da arte em Análise Estática Automatizado até o momento da elaboração desse TCC. Com a motivação de melhorar a análise estática para *bugs* contextualizados de específicos projetos, utilizando *rulesets* lidando com o máximo de casos (*corner-cases*) diminuindo o trabalho braçal e capacidade de migrar regras para diferentes linguagens (HOU et al., 2025).

Os autores citam KNighter, explicando que apesar de sua efetividade, KNighter não possui dinâmica para lidar com diferentes linguagens, exigindo diversas alterações manuais para conseguir seu funcionamento (HOU et al., 2025). Propondo um novo método baseado em LLMs que gera regras de análise estática a partir de padrões de históricos de código, utilizando regras gramáticas e *few-shot learning* em contexto, além de suporte para migração de regras existentes para outras linguagens, geração de exemplos para cada regra especificado para lidar com *corner-cases* (HOU et al., 2025).

Arquiteturamente, o *framework* proposto adota uma estratégia de *few-shot learning* para administrar conhecimento do domínio adquirido das LLMs durante seu pré-treinamento não supervisionado, integrando especificações de sintaxe de regras, histórico de informações de erros e descrição de otimizações de regras para guiar o comportamento de geração de regras das LLMs (HOU et al., 2025). Hou et al. (2025) apontam que isso efetivamente soluciona dificuldades em *corner-cases* que seriam mais complexos para um humano criar,

diminuindo o caso de falsos positivos e falsos negativos.

A ferramenta de análise estática utilizada, para reduzir o uso de apenas LLMs, é SemGrep. Os autores explicam que análise estática baseada em regras proveem extensibilidade por suas regras customizaveis, permitindo checagens para problemas específicos para projetos específicos (HOU et al., 2025).

Consequentemente, Hou et al. (2025) afirma que não existe necessidade da construção de um analisador específico para realizar essas checagens. Para o objetivo do artigo com migração de regras, SemGrep se encaixa perfeitamente por seu suporte a mais de 30 linguagens, mimetizando qualquer das linguagens suportadas com seu arquivo YAML (HOU et al., 2025).

Do ponto de vista técnico, a abordagem proposta segue um *workflow* de três estágios: a Geração, Migração e Otimização das regras. No estágio inicial de Geração, o método dos autores é reconhecimento de *patches* de código e gera descrições das regras, assim gera a regra a partir da descrição. Com as regras geradas, cada uma é avaliada em *snippets* de teste para verificar uma eficácia, então as descrições das regras podem ser otimizadas de acordo com falsos positivos e falsos negativos (HOU et al., 2025).

Para o segundo estágio, seu método gera descrições de linguagens naturais e seus *snippets* de teste para a migração da regra, subsequentemente criando a regra. No último estágio, seu método lê a regra criada, independente se foi gerada ou não, e cria *snippets* para lidar com *corner-cases*, seguindo os mesmos passos do estágio um (HOU et al., 2025).

Sua construção de metodologia segue um fluxo similar ao Yang et al. (2025), apesar de criar uma avaliação extra relacionada à migração de linguagens. Para a utilização de *datasets* para treinamento, Hou et al. (2025) utiliza, para geração de regras, foram selecionadas aleatóriamente 111 regras dentre o *ruleset* oficial do SemGrep, cada regra contendo um YAML e *snippets* de um código com *bugs* e sua correção, inserindo cada regra para seu agente realizar a descrição de cada regra, com uma validação manual para garantir que as descrições correspondiam a cada regra.

Para a adaptação de gramática do SemGrep, Hou et al. (2025) utiliza a documentação oficial do SemGrep, incluindo partes relacionadas a Sintaxe de Regras e Sintaxe de Padrões. Convertendo o texto para *Markdown*, e inserindo a gramática no contexto dos agentes. Apesar de a documentação ser feita para leitores humanos, Hou et al. (2025) inseriram códigos exemplos para um treinamento *few-shot* para sua familiarização com a gramática.

Para validar seu experimento, Hou et al. (2025) utilizam três validações.

Validação Gramática, regras com a gramática válida são aquelas que a regra gerada é reconhecida pela ferramenta de análise estática, para essa avaliação, foi aplicado cada regra com uma amostra de código aplicado na ferramenta, e examinado se SemGrep relata algum erro de gramática para a regra (HOU et al., 2025);

Validação Funcional, uma regra é funcionalmente válida a partir que as regras geradas conseguem reportar *bugs* em uma amostra de teste. Para cada amostra de teste,

contendo N *bugs* que se encaixam na respectiva regra, se a regra produzida retorna B_{VP} verdadeiros positivos e B_{FP} falsos positivos, é definido dois indicativos para avaliar a validade da regra: (HOU et al., 2025)

$$Taxa\ de\ Falsos\ Positivos : FP = \frac{B_{FP}}{N} \tag{2.7}$$

$$Taxa\ de\ Verdadeiros\ Positivos : TP = \frac{B_{VP}}{N} \tag{2.8}$$

Utilizando essa metodologia de avaliação, Hou et al. (2025) utiliza o trabalho de Yang et al. (2025) como comparação de eficácia. Como o trabalho de KNighter provê publicamente um *dataset* com 61 *commits* de *bugs fixes* no Kernel Linux, contendo o erro e sua correção, Hou et al. (2025) avalia seu método para, além de comparar com KNighter mas, avaliar sua performance no Kernel Linux.

Resultados de Hou et al. (2025) criaram 41 regras válidas comparadas com as 37 geradas por Yang et al. (2025), modestiamente ultrapassando performance contra KNighter, apesar dos autores afirmarem que seu trabalho precisa de mais refinamento. Além de comparar com KNighter, Hou et al. (2025) compara sua efetividade contra ferramentas comuns de análise estática como Smatch, CPPCheck, *ruleset* oficial do SemGrep e TScanCode. Nenhuma das ferramentas identificaram os mesmos de alguns *bugs* que sua metodologia conseguiu, que os autores dizem ser talvez pela falta de conhecimento do domínio específico do projeto analisado que métodos baseados em LLMs conseguem detectar (HOU et al., 2025).

Para o presente trabalho, o estudo de Hou et al. (2025) cumpre dois papéis fundamentais.

Primeiro, apresenta aprimoramentos comparado com o seu pioneiro KNighter com seu fluxo lógico interpretativo, se mostrando promissor utilizando ferramentas sem limites de linguagem, Hou et al. (2025) mostra que SemGrep, com suas funções lógicas, auxilia para evitar falsos positivos, apesar de seu custo computacional pelos diversos agentes.

Segundo, estabelece o referencial na utilização de ferramentas tradicionais para integração com LLMs. Mesmo sem integração de outros *datasets* para inclusão de novas regras, Hou et al. (2025) foi capaz de exceder em performance pela mudança de *workflow* para cada *commits*.

2.3.3 Trabalho 3: *RepoAudit: An Autonomous LLM-Agent for Repository-Level Code Auditing* (GUO et al., 2025)

O trabalho de Guo et al. (2025), desenvolvido na Universidade Purdue e publicado na 42ª *International Conference on Machine Learning* (ICML 2025), em Vancouver, Canadá, apresenta o RepoAudit, um agente autônomo baseado em LLMs para auditoria de código em nível de repositório, isto é, a revisão de um projeto inteiro com o objetivo de identificar *bugs*.

Os autores partem da constatação de que auditar um repositório com LLMs esbarra em três obstáculos: a janela de contexto limitada, as alucinações, que degradam a qualidade dos relatórios, e o alto custo de tempo e de *tokens* ao analisar projetos de larga escala (GUO et al., 2025).

Dividir o repositório em pedaços e submetê-los individualmente ao modelo também não resolve o problema, pois muitas falhas são não locais: dependem de valores que atravessam diversas funções, classes e arquivos. Como exemplo, o número de arestas de fluxo de dados do projeto *shadowsocks-libev* ultrapassa um milhão (GUO et al., 2025).

Além disso, diversos tipos de falha são sensíveis ao caminho de execução. Um vazamento de memória (CWE-401), por exemplo, ocorre quando a memória alocada deixa de ser liberada em ao menos um dos caminhos possíveis do programa, e enumerar todos esses caminhos leva à conhecida explosão de caminhos, já que o seu número cresce exponencialmente com o tamanho do código (GUO et al., 2025).

Ao analisar a lista CWE Top 25 de 2024, os autores concluem que 19 das 25 categorias (76%) exigem raciocínio global e sensível ao caminho sobre grafos de chamadas, de dependência de dados e de fluxo de controle, enquanto apenas seis podem ser identificadas por análises localizadas sobre a AST (GUO et al., 2025).

Inspirado no comportamento de auditores humanos, que seguem o código na ordem de execução e percorrem apenas os caminhos relevantes para a propriedade investigada, o RepoAudit é organizado em três componentes (GUO et al., 2025):

(i) Iniciador, que identifica os pontos de partida da análise (as fontes), como os valores `NULL` na busca por desreferenciamento de ponteiro nulo. Para isso, utiliza a biblioteca de *parsing tree-sitter* e um conjunto de casadores de padrões escritos uma única vez para cada tipo de falha; os próprios autores apontam a síntese desses casadores por LLMs como um caminho promissor (GUO et al., 2025);

(ii) Explorador, que percorre o repositório sob demanda, analisando uma função por vez. Para cada função, o modelo é instruído a abstrair o programa, mantendo apenas as instruções relevantes, a tratar ponteiros e apelidos (*aliases*) e a coletar os caminhos viáveis, identificando os fatos de fluxo de dados a partir da fonte. Os resultados são guardados em uma memória do agente, que também funciona como *cache* para evitar análises repetidas, e a exploração só avança para funções chamadoras ou chamadas quando o valor investigado escapa da função atual. Um candidato a *bug* é gerado quando a fonte alcança um ponto crítico (*sink*), como a desreferência de um ponteiro, ou, no caso de vazamentos de memória, quando não alcança nenhuma chamada a `free` (GUO et al., 2025);

(iii) Validador, que reduz as alucinações por dois mecanismos: um analisador baseado em *parsing* confirma que cada fato de fluxo de dados respeita a ordem do fluxo de controle antes de ser armazenado, e uma nova consulta ao modelo verifica se as condições de caminho entre funções diferentes não se contradizem, descartando o relatório caso se contradigam (GUO et al., 2025).

Na avaliação, o RepoAudit foi executado com o modelo Claude 3.5 Sonnet, com temperatura zero e análise limitada a cadeias de no máximo quatro funções, sobre três tipos de falha presentes na lista CWE Top 25: desreferenciamento de ponteiro nulo (CWE-476), vazamento de memória (CWE-401) e uso após liberação (CWE-416). Foram utilizados quinze projetos reais, com média de 251 mil linhas de código, entre eles subsistemas do *kernel* do Linux, Redis, memcached e ImageMagick (GUO et al., 2025).

O agente reproduziu todos os 21 *bugs* relatados em trabalhos anteriores e encontrou 19 novos, totalizando 40 verdadeiros positivos e 11 falsos positivos, uma precisão de 78,43%, com custo médio de 0,44 hora e US$ 2,54 por projeto (GUO et al., 2025). Nos mesmos projetos, a ferramenta industrial Meta Infer relatou 7 verdadeiros positivos e 2 falsos positivos, mas não pôde ser aplicada a parte dos projetos por depender de compilação, enquanto o Amazon CodeGuru relatou 18 falsos positivos e nenhum verdadeiro positivo (GUO et al., 2025).

O estudo de ablação reforça a importância de cada componente: sem a etapa de abstração, o número de verdadeiros positivos cai 47,50% e o de falsos positivos aumenta 181,82%; sem os validadores, os falsos positivos aumentam 245,45%; e sem a memória utilizada como *cache*, o custo fica de três a quatro vezes maior em média (GUO et al., 2025). Aplicado a nove projetos *open-source* ativos, o RepoAudit detectou 185 *bugs* com precisão de 85,71%, dos quais 95 foram confirmados e 79 corrigidos pelos desenvolvedores (GUO et al., 2025).

Como limitações, os autores apontam que, além dos falsos positivos e negativos causados por alucinações, o custo da análise cresce com o número de fontes presentes no repositório e que a ferramenta não é *sound* na análise entre funções, podendo perder falhas que envolvam cadeias de chamadas com mais de quatro funções (GUO et al., 2025).

Para o presente trabalho, o RepoAudit é relevante por três motivos. Primeiro, cobre três das cinco CWEs adotadas neste TCC, oferecendo uma referência direta de desempenho para as mesmas classes de falha. Segundo, demonstra empiricamente que etapas de validação reduzem de forma expressiva os falsos positivos gerados por LLMs, o que fundamenta o agente de validação do *pipeline* proposto (Seção 3.2.2). Terceiro, evidencia o principal contraste com esta proposta: o RepoAudit consulta o modelo a cada auditoria, de modo que o custo se repete a cada execução e cresce com o tamanho do projeto, enquanto este trabalho utiliza a LLM apenas para gerar regras, que depois são executadas pelo SemGrep sem custo de inferência.

2.3.4 Síntese comparativa

A análise individual dos três trabalhos relacionados permite, em conjunto, delinear com precisão o estado da arte em Análise Estática Baseado em LLMs e identificar lacunas que este TCC busca preencher. Para facilitar essa análise, a Tabela 2 sintetizam as

características técnicas dos trabalhos relacionados entre si e o diferencial introduzido pela proposta deste trabalho.

Tabela 2 – Comparação técnica entre os trabalhos relacionados

Critério	**Yang et al. (2025)**	**Hou et al. (2025)**	**Guo et al. (2025)**	**Este trabalho**
Foco principal	Geração automatizada de verificadores estáticos a partir de histórico de *patches*.	Geração, otimização e migração multilinguagem de regras de análise estática.	Auditoria autônoma de repositórios inteiros por um agente LLM guiado por fluxo de dados.	Geração de regras automatizada a partir de histórico de *patches* e *datasets*.
Método/ Tecnologia	LLMs + Clang Static Analyser (CSA)	LLMs (*few-shot learning*) + SemGrep	LLM (Claude 3.5 Sonnet) + agente com memória e validadores (*tree-sitter*).	LLMs (*few-shot learning*) + *CWEs datasets* + SemGrep
Métrica Principal de Avaliação	Taxa de validade dos *checkers* e volume de novos *bugs* detectados.	Validade sintática/ funcional e eficácia na transposição de regras entre linguagens.	Precisão, *bugs* verdadeiros detectados e custo (tempo e US$ por projeto).	*Recall*, Taxa de Falsos Positivos e custo computacional (tempo/ *tokens*).
Limitação / Trabalho Futuro	Acoplamento estrito ao ecossistema C/C++ e geração de falsos positivos diante de lógicas de estado complexas.	Alta taxa de falsos positivos e dificuldade em fluxo de dados.	Custo proporcional ao número de fontes e análise entre funções limitada a quatro funções.	–

Fonte: Elaborado pelo autor (2026)

3 Desenvolvimento / Implementação / Experimentos

Este capítulo apresenta a proposta de desenvolvimento deste trabalho, detalhando a arquitetura do sistema, as decisões metodológicas, o planejamento experimental e o cronograma de execução previstos para TCC2. Expandindo como será realizada cada etapa da solução, bem como serão apresentados prazos para cada fase.

Em sincronia com a proposta de pesquisa, o foco está na especificação precisa do que será implementado e avaliado (WAZLAWICK, 2020).

3.1 Metodologia da pesquisa

Este trabalho utiliza o método *Design Science Research* (DSR), conforme definido Hevner et al. (2004), como método científico orientador. O DSR é um paradigma de pesquisa fundamentalmente focado na resolução de problemas, responsável por produzir quatro tipos de artefatos: constructos, modelos, métodos, instanciações (HEVNER et al., 2004).

O ciclo deste trabalho está estruturado em quatro fases: (1) **construção de *dataset***, organização e identificação de *datasets* públicos e banco de *commits* de bases de código de projetos *open-source*; (2) ***pipeline* de geração de regras**, aplicação de LLMs em um *pipeline* para gerar regras satisfatórias para a ferramenta SemGrep; (3) **avaliação de resultados**, analisar cada relatório para obter taxa de falsos positivos no *dataset* de aprendizado; (4) **aplicação no mundo real**, com o conjunto de regras, será analisado os resultados em projetos *open-source* como Linux Kernel.

3.2 Detalhes da implementação

3.2.1 Visão geral da solução proposta

A solução proposta consiste em uma Extensão Geradora de Regras baseado em LLMs direcionada a Projetos de Larga Escala para a ferramenta de análise estática, SemGrep. O *pipeline* recebe o código-fonte como entrada e utiliza uma LLM para analisar trechos de verificações de segurança e *border-cases* não-tratados. A partir da identificação padrões e potenciais vulnerabilidades, o sistema gera automaticamente regras personalizadas compatíveis com o SemGrep.

Figura 9 – Arquitetura do pipeline proposto

Dataset	→	**Análise**	→	**Geração de Regras**	→	**Otimização**	→	**Ferramenta**
Código-Fonte		Possíveis CWEs		Regras dinâmicas		Fusão de casos		Conjunto de regras

Fonte: Elaborado pelo autor (2026)

3.2.2 Arquitetura do trabalho

Este trabalho é organizado em dois módulos principais independentes e complementares: um *dataset* global unificado de CWEs e uma camada de *pipeline* geradora de regras baseada em LLMs. Capaz de gerar regras a partir de qualquer projeto e analisar os *commits* somando o conhecimento do *dataset*.

1. **Módulo de *Dataset***: A base de conhecimento do sistema é estruturada a partir de do repositório provido por NSA Center for Assured Software (2017). Esta fonte fornece um volume expressivo de amostras de código categorizadas por CWEs, viabilizando o treinamento e a validação do modelo. Para complementar essa base estática e garantir a cobertura de *corner-cases* do mundo real, o módulo também realiza a coleta e integração de históricos de *commits* extraídos de projetos *open-source* ativos. Além da base de NSA Center for Assured Software (2017), será coletado históricos de *commits* de projetos *open-source* ativos, obtendo mais exemplos de *corner-cases*.

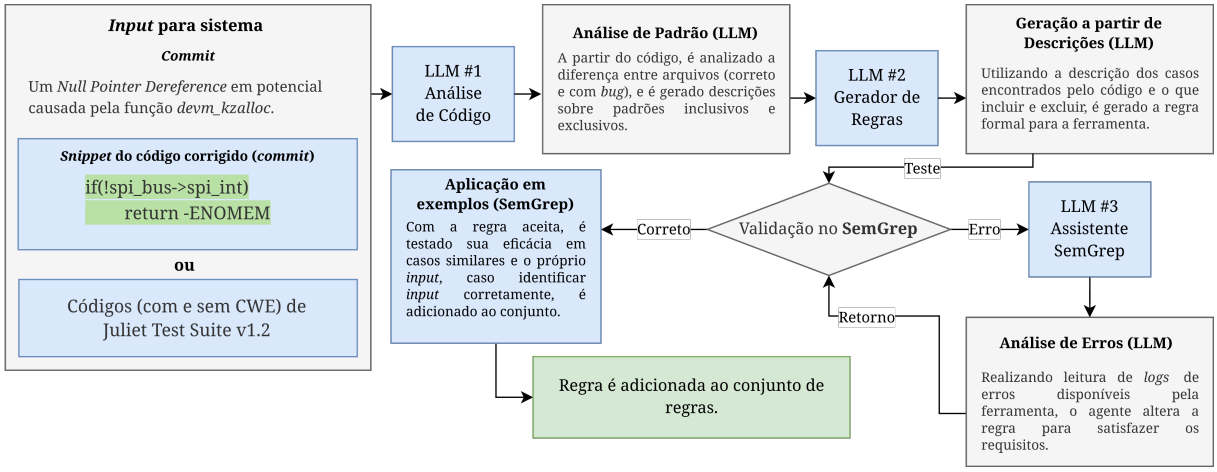
2. **Camada do *Pipeline* (Agentes LLM)**: O fluxo de abstração, síntese e otimização das regras ocorre de maneira iterativa, orquestrado por um conjunto de agentes especializados. Em vez de uma execução linear rígida, o sistema adota um ciclo de retroalimentação visualizado integralmente na Figura 10 e na Figura 11. O funcionamento da camada abstrai-se nas seguintes frentes:

    - **Análise e Abstração (Agente #1)**: Recebe os fragmentos de código (vulneráveis e corrigidos) e sintetiza um relatório destacando os padrões diferenciais e a lógica da falha.
    - **Síntese de Sintaxe (Agente #2)**: Traduz o relatório abstraído para a gramática formal de regras exigidas pela ferramenta SemGrep.
    - **Assistência e Validação (Agente #3)**: Atua no controle de qualidade; caso o motor do SemGrep acuse erros sintáticos durante a validação da regra gerada, este agente interpreta os *logs* de erro e aplica as correções necessárias de forma iterativa. Caso a regra continua rejeitada pela ferramenta depois de três tentativas, será descartada, para evitar consumo infinito de memória e *tokens*.
    - **Otimização Contínua e Consolidação de Regras (Agente #4)**: Após a aprovação e eficácia comprovada, as regras são integradas ao conjunto principal.

Este agente realiza uma varredura periódica para unificar regras que tratam do mesmo CWE, consolidando padrões e maximizando a abrangência de *corner-cases*.

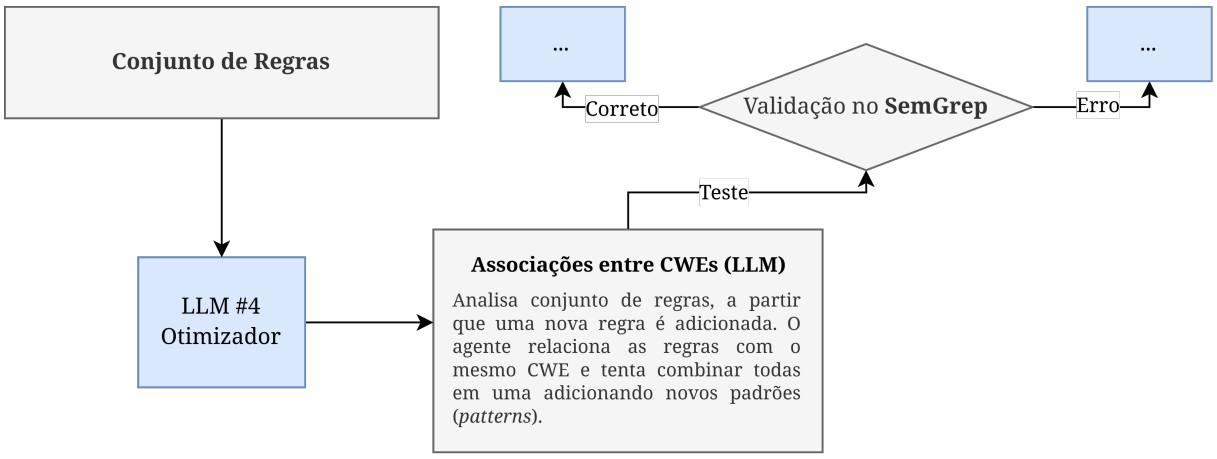
Alinhado aos objetivos específicos (Seção 1.3.2), a arquitetura foi desenhada priorizando a adoção de modelos de linguagem de menor escala (com menos parâmetros) para a orquestração destes agentes. Essa decisão visa viabilizar a execução do *framework* em infraestruturas locais, otimizando o consumo computacional e o gasto de *tokens*.

Figura 10 – *Pipeline* para gerador de regras.



Fonte: Elaborado pelo autor (2026)

Figura 11 – Pós-processamento para otimizar regras e abranger *corner-cases*



Fonte: Elaborado pelo autor (2026)

3.2.3 Arquitetura efetivamente implementada

Durante a implementação, a arquitetura de quatro agentes descrita nesta seção foi consolidada em um ciclo mais enxuto, definido empiricamente ao longo dos experimentos.

Em vez de quatro agentes LLM distintos operando em sequência fixa, o sistema implementado estrutura-se em dois papéis centrais executados por modelos de linguagem – **gerador** e **corretor** – e um componente determinístico, o ***gate* de avaliação**, responsável por validar sintaticamente, executar e avaliar quantitativamente cada regra candidata.

O papel de **gerador** corresponde, em essência, à fusão dos antigos Agentes #1 e #2 (análise/abstração e síntese de sintaxe): a partir dos exemplos de código vulnerável e seguro de um CWE, o gerador escreve diretamente a regra candidata, no formato de saída configurado (Seção 3.2.4).

O *gate*, por sua vez, substitui a função de validação originalmente atribuída ao Agente #3, porém de forma inteiramente determinística: um módulo em *Python* normaliza a resposta do modelo, verifica a validade estrutural da regra (posicionamento correto dos operadores do SemGrep, presença de ao menos um matizador de alto nível, terminação de instruções em C), aplica uma checagem lexical (*lint*) que rejeita regras que reutilizem identificadores específicos dos exemplos de treinamento em vez de metavariáveis, executa o motor do SemGrep sobre os arquivos de treinamento e computa *recall*, precisão e taxa de falsos positivos.

O papel de **corretor** herda a função reativa do antigo Agente #3: recebe a regra candidata e o relatório de erros ou métricas do *gate* e produz uma nova versão da regra, em um ciclo iterativo limitado a um número configurável de tentativas (até seis, em vez das três originalmente previstas, valor que se mostrou necessário para regras mais complexas).

Uma regra é considerada **aprovada** quando, no conjunto de treinamento, atinge *recall* mínimo de 50%, não produz nenhum falso positivo nos casos sintéticos do Juliet Test Suite e não ultrapassa 0,1 alertas por mil linhas de código (KLOC) ao ser executada sobre uma base de código real assumida como correta (Seção 3.2.7). Caso o orçamento de tentativas se esgote sem aprovação, a melhor tentativa observada é mantida apenas para fins de avaliação no conjunto de teste, não sendo incorporada ao conjunto final de regras.

Dois papéis adicionais, inspirados na função de consolidação do antigo Agente #4, foram implementados como mecanismos opcionais e avaliados experimentalmente: o **crítico**, que revisa uma regra reprovada e explica textualmente a causa provável da falha antes que o corretor atue; e o **fusor** (*merger*), que combina a regra de melhor desempenho com a regra mais "silenciosa" (menor taxa de falsos positivos) obtida ao longo das tentativas, em uma tentativa final de síntese.

Complementarmente, três mecanismos de controle foram avaliados: o ***guard***, que impede que uma correção substitua a melhor regra já encontrada caso a nova versão apresente pontuação inferior; o `project_apis`, que insere no *prompt* os nomes das funções de memória próprias do projeto-alvo; e o parâmetro de **modo de exemplos** (`example_mode`), que determina o que é mostrado ao gerador – os achados do detector (`findings`, padrão), pares de código vulnerável/seguro do *dataset* (`pairs`), achados da análise de grafos de eventos (`graph`) ou nenhum exemplo (`none`).

3.2.4 Formatos de saída das regras

Ao longo dos experimentos, cinco formatos distintos de saída foram implementados e avaliados para a regra candidata, cada um restringindo de forma diferente a liberdade do modelo gerador:

1. **`yaml`**: o modelo escreve livremente a regra completa na gramática YAML do SemGrep, sem restrição estrutural além da instrução textual do *prompt*;
2. **`spec`**: o modelo escreve uma especificação em JSON dos padrões, posteriormente traduzida deterministicamente para a gramática do SemGrep;
3. **`template`**: o modelo preenche uma estratégia pré-definida de rastreamento de contaminação (*taint*), representada como um JSON de preenchimento, reduzindo a liberdade de síntese à escolha dos padrões e nomes de funções relevantes;
4. **`form`**: o modelo preenche as lacunas de uma regra em modo *taint* (fonte, desinfetantes e usos perigosos de uma variável), com o decodificador do modelo restrito por uma gramática formal do esqueleto, impedindo a geração de qualquer estrutura fora do esquema previsto;
5. **`formsearch`**: equivalente ao anterior, porém para o modo de busca (*search*) do SemGrep, utilizado quando o CWE-alvo não admite um ponto de partida de contaminação (como uma declaração de variável sem valor atribuído).

Para os formatos `form`, `formsearch` e `yaml`, foi implementado adicionalmente um modo de correção alternativo, denominado `field_correct`: em vez de reescrever a regra inteira a cada tentativa de correção, o corretor responde apenas com o novo valor de um único campo (um padrão, uma exclusão ou um padrão de exclusão de contexto), escolhido ciclicamente a cada tentativa, enquanto o restante da regra permanece inalterado.

Esse mecanismo busca contornar um comportamento recorrente observado nos modelos de menor porte: ao receber a mesma mensagem de erro repetidamente, o modelo tende a reenviar a regra anterior, idêntica, em vez de produzir uma variação (Seção 3.4.2).

Uma limitação identificada durante a implementação é que a correção por campo só é aplicável quando a estrutura da regra já é válida; quando o gerador produz uma regra com um erro estrutural (por exemplo, um operador do SemGrep posicionado de forma inválida), o sistema recorre automaticamente à reescrita completa, já que a edição de um único valor não é capaz de corrigir a posição de um operador.

3.2.5 O analisador de grafos de eventos: um componente complementar e determinístico

O modo de exemplos `graph` (Seção 3.2.3) é alimentado por um componente desenvolvido em um ramo (*branch*) separado do repositório deste trabalho, que não utiliza nenhum

modelo de linguagem: um analisador de grafos de eventos de memória.

Para cada função do código-fonte analisado, esse componente constrói, por meio de *tree-sitter*, um grafo de eventos (alocação, liberação, uso, reatribuição) conectados por arestas de fluxo de controle, e executa sobre ele consultas de alcançabilidade – por exemplo, para o CWE-416, uma busca por todo caminho que leve de uma liberação (`free($p)`) a um uso subsequente da mesma variável sem reatribuição intermediária.

A motivação para o desenvolvimento desse componente foi dupla:

(i) avaliar se uma abordagem inteiramente determinística, sem o custo de inferência de um modelo de linguagem, seria capaz de, isoladamente, atingir o mesmo critério de qualidade estabelecido neste trabalho para as regras sintetizadas – *recall* elevado no Juliet Test Suite e no máximo 0,1 alertas por KLOC sobre código real assumido como correto (Seção 3.2.7);

(ii) testar se seus achados, por identificarem precisamente as duas linhas de código envolvidas em cada ocorrência (a liberação e o uso posterior), constituiriam exemplos de treinamento de maior qualidade para o gerador do que os achados, predominantemente textuais, do detector inicial de 3 bilhões de parâmetros.

Como detector autônomo, após sucessivas rodadas de generalização de seus eventos e de inferência estatística dos nomes de função de alocação e liberação específicos de cada projeto – sem nenhuma lista de nomes escrita manualmente, a partir do próprio uso que o código faz da biblioteca padrão de C –, o analisador atingiu 134 dos 138 casos de CWE-416 do Juliet Test Suite, sem nenhum falso positivo, e manteve-se abaixo do limite de 0,1 alertas por KLOC em diversos projetos de código real nunca utilizados em seu desenvolvimento (entre eles *tmux*, *PostgreSQL* e *SQLite*), embora tenha falhado em outros (no *vim*, uma única função de liberação inferida incorretamente respondeu por 179 dos 234 alertas emitidos).

Esse resultado é relevante por si: demonstra que o objetivo central deste trabalho – detectar a vulnerabilidade de forma precisa e silenciosa em código real – é alcançável por uma via inteiramente distinta da síntese de regras por LLM aqui proposta, ainda que por um caminho que não produz, como artefato final, uma regra executável pela ferramenta-alvo definida no escopo deste trabalho, o SemGrep (Seção 1.4).

3.2.6 Combinações de modelos avaliadas

Para viabilizar a execução do *framework* em *hardware* local e investigar o Objetivo Específico 3 (Seção 1.3.2), diversas combinações de modelos de linguagem foram configuradas e avaliadas ao longo do trabalho, detalhadas na Tabela 3. Todas as combinações utilizam o mesmo modelo de 3 bilhões de parâmetros (Qwen2.5-Coder-3B) na etapa de detecção inicial de vulnerabilidades, variando o modelo responsável pela geração e correção das regras.

Tabela 3 – Combinações de modelos de linguagem avaliadas

Combo	**Modelo gerador/corretor**
A	Qwen2.5-Coder-3B em todos os papéis
B	Qwen2.5-Coder-7B
C	Qwen3-4B-Instruct-2507
D	Qwen3-Coder-30B-A3B (*Mixture-of-Experts*, aproximadamente 3 bilhões de parâmetros ativos por *token*, com *offload* parcial para GPU)
E	Qwen3-Coder-30B-A3B, sem troca de modelos entre papéis
F	Phi-4-mini

Fonte: Elaborado pelo autor (2026)

A combinação D, apesar de seu custo computacional mais elevado e tempo de inferência por *token* consideravelmente maior, demonstrou-se necessária para a obtenção dos melhores resultados do trabalho (Seção 3.4.3): a combinação C, baseada em um modelo de 4 bilhões de parâmetros, não foi capaz de reproduzir os ganhos obtidos pelo mecanismo `field_correct`, evidenciando uma relação direta entre a capacidade do modelo gerador e a eficácia de mecanismos de correção mais refinados.

3.2.7 Protocolo de avaliação

A avaliação de cada regra sintetizada segue um protocolo de validação cruzada por dobras (*k-fold cross-validation*), com $k = 5$, estratificado pelas variantes de fluxo do Juliet Test Suite, de forma que cada variante sintática de um CWE seja utilizada no conjunto de teste exatamente uma vez ao longo das cinco dobras.

Para mitigar o efeito de variação amostral identificado ao longo do trabalho (Seção 3.4.4), cada configuração experimental foi repetida com múltiplas sementes (*seeds*) de particionamento, inicialmente duas e, nas configurações consideradas mais relevantes, estendidas a cinco.

Além da avaliação sobre o *dataset* sintético, cada regra candidata é também executada sobre uma base de código real de um projeto *open-source* maduro (o repositório *git/git*), assumida como funcionalmente correta.

Essa segunda avaliação, denominada *gate* de negativos do mundo real, quantifica a taxa de alertas por mil linhas de código (KLOC) que a regra dispara sobre código idiomático e não-vulnerável, funcionando como um critério de qualidade mais rigoroso e realista do que a simples ausência de falsos positivos no *dataset* sintético: uma regra pode atingir zero falsos positivos nos casos de teste do Juliet e, ainda assim, disparar constantemente sobre código real, caso seus padrões sejam genéricos ou mal direcionados.

Uma regra somente é considerada aprovada quando atinge *recall* mínimo de 50% no conjunto de treinamento, nenhum falso positivo no Juliet Test Suite e taxa de alerta no

mundo real igual ou inferior a 0,1 alertas por KLOC.

Durante a execução dos experimentos, identificou-se e corrigiu-se uma falha de robustez no *gate*: regras candidatas com padrões patologicamente ineficientes ocasionalmente faziam o motor do SemGrep travar ou encerrar de forma anômala ao ser executado sobre a base de código real, interrompendo todo o processo de validação cruzada em andamento. A correção implementada trata esse travamento ou encerramento anômalo como um erro comum de regra inválida, permitindo que o ciclo gerador-corretor prossiga normalmente para a próxima tentativa, em vez de encerrar o processo inteiro.

3.3 Experimentos e cenário de testes

Os experimentos conduzidos na segunda etapa deste trabalho têm como objetivo avaliar empiricamente a arquitetura descrita na Seção 3.2 sobre cinco categorias de vulnerabilidade (CWE-401, CWE-415, CWE-416, CWE-457 e CWE-476, descritas na Seção 2.2.2.2), variando o formato de saída da regra, a combinação de modelos e os mecanismos opcionais do corretor (Seção 3.2.3).

Cada rodada experimental segue o protocolo de avaliação descrito na Seção 3.2.7, com os arquivos de treinamento e teste extraídos do Juliet Test Suite (NSA Center for Assured Software, 2017) e a base de código real do repositório *git/git* utilizada como fonte de negativos do mundo real.

O planejamento experimental organizou-se em quatro rodadas sucessivas, cada uma definida e registrada previamente à sua execução, seguindo o princípio de *Design Science Research* de avaliação rigorosa e documentada (HEVNER et al., 2004).

3.3.1 Rodada 1: viabilidade do formato de preenchimento de lacunas (CWE-457)

A primeira rodada experimental teve como objetivo avaliar se restringir a liberdade sintática do modelo gerador, por meio dos formatos `form` e `formsearch` (Seção 3.2.4), produz regras mais eficazes do que o formato livre `yaml` para o CWE-457 (uso de variável não inicializada), um caso nunca antes avaliado pelo *pipeline*.

Antes da execução, dois fatos foram estabelecidos manualmente, a partir de regras escritas pelo próprio autor sobre os arquivos do Juliet Test Suite:

(i) em modo *taint*, uma declaração de variável sem atribuição de valor não é capaz de iniciar o rastreamento de contaminação no motor do SemGrep *Open Source*, de forma que qualquer regra no formato `form` está estruturalmente limitada a 0% de *recall* para este CWE;

(ii) uma regra em modo de busca, combinando a declaração, qualquer código intermediário e um uso posterior da variável, excluindo o mesmo padrão quando precedido

de uma atribuição, atinge um *recall* de aproximadamente 31% sem falsos positivos nos primeiros 120 pares de arquivos do Juliet, valor que serve como teto de referência para a capacidade do próprio formato, independentemente do modelo utilizado.

Os quatro formatos (`yaml`, `template`, `form` e `formsearch`) foram avaliados na combinação C (Qwen3-4B-Instruct), com validação cruzada de cinco dobras, duas sementes e até seis tentativas de correção por dobra.

3.3.2 Rodadas 2 a 4: mecanismo `field_correct` (CWE-416 e CWE-415)

As três rodadas subsequentes investigaram o mecanismo de correção por campo (`field_correct`, Seção 3.2.4) sobre os formatos `form` e `formsearch`, aplicados ao CWE-416 (uso após liberação) e ao CWE-415 (liberação dupla), dois CWEs cuja semântica se encaixa naturalmente em uma estrutura de rastreamento de contaminação (fonte: `free($P)`; uso perigoso: qualquer acesso posterior ao ponteiro, no caso do CWE-416, ou uma segunda chamada a `free($P)`, no caso do CWE-415).

A Rodada 2 avaliou os quatro arranjos (`form` e `formsearch`, com e sem `field_correct`) para ambos os CWEs na combinação C; a Rodada 3 repetiu exatamente os mesmos dezesseis experimentos na combinação D (Qwen3-Coder-30B-A3B), isolando o efeito do porte do modelo gerador; a Rodada 4 investigou o acúmulo do `field_correct` com o parâmetro `example_mode=pairs` (Seção 3.2.3), ambos considerados, isoladamente, os mecanismos mais promissores identificados até então. No total, 48 execuções de validação cruzada foram realizadas ao longo destas três rodadas.

3.3.3 Revisão da configuração de referência e rodada final (CWE-416)

Paralelamente às rodadas anteriores, um levantamento consolidado de todas as 120 execuções de validação cruzada realizadas até então foi conduzido, identificando a única configuração já aprovada pelo *gate* ao longo de todo o trabalho: a combinação D, formato `template`, com o parâmetro `example_mode=pairs` (pares de código vulnerável e seguro apresentados ao gerador, em vez dos achados do detector), aplicada ao CWE-416, aprovando duas das cinco dobras na primeira semente avaliada.

A partir desse achado, conduziu-se uma rodada final de refinamento:

(i) extensão da configuração `pairs` para cinco sementes, de forma a avaliar sua estabilidade;

(ii) combinação de `pairs` com os mecanismos `guard` (nunca piorar a melhor regra já encontrada) e `project_apis` (nomes de funções do projeto-alvo no *prompt*);

(iii) uma configuração isolando apenas o mecanismo `guard`, sem o `project_apis`, também estendida a cinco sementes.

3.4 Resultados e análises

Esta seção apresenta e discute os resultados quantitativos obtidos nas quatro rodadas experimentais descritas na Seção 3.3. A Tabela 4 sintetiza o melhor resultado obtido para cada categoria de vulnerabilidade avaliada ao longo do trabalho.

Tabela 4 – Síntese dos melhores resultados por CWE

CWE	**Melhor configuração**	***Recall***	**Dobras aprovadas**
CWE-416	Combo D, `template`, `pairs` + `guard`	89,2%–100%	2 de 5 sementes*
CWE-415	Combo D, `yaml`, `example_mode=graph`	43,3%–76,3%	0 de 5
CWE-401	Combo G, execução isolada (sem validação cruzada)	79,47%	–
CWE-476	Combo D, `yaml`, `example_mode=graph`	22,9%–24,8%	0 de 2
CWE-457	Combo C, `formsearch`	0%–18,75%	0 de 2

Fonte: Elaborado pelo autor (2026). *Cada semente aprovada contribui com, no mínimo, uma de cinco dobras.

3.4.1 CWE-457: um alvo estruturalmente inadequado

Nenhum dos quatro formatos avaliados para o CWE-457 obteve aprovação em qualquer dobra, nas duas sementes testadas (20 execuções no total). O formato `form`, em modo *taint*, confirmou a limitação estrutural identificada previamente à execução (Seção 3.3.1): por não haver atribuição de valor em uma declaração de variável, o motor do SemGrep não é capaz de iniciar o rastreamento de contaminação a partir dela, limitando o *recall* de toda regra desse formato a 0%, independentemente da qualidade dos demais campos preenchidos pelo modelo.

Os formatos `yaml` e `template` produziram, na maioria das dobras, regras sintaticamente válidas e aceitas sem erro pelo motor do SemGrep, porém completamente inertes: *recall* de 0% e nenhum falso positivo, indicando que o modelo de 4 bilhões de parâmetros utilizado (combinação C) não foi capaz de sintetizar um padrão que, de fato, correspondesse ao uso de uma variável não inicializada em código C genérico.

Apenas o formato `formsearch` apresentou alguma capacidade de detecção, atingindo 18,75% de *recall* em uma dobra, acompanhado de 288 falsos positivos, e 0% nas demais, com taxa de alerta no mundo real entre 0,22 e 0,48 alertas por KLOC – acima do limite de 0,1 estabelecido pelo *gate*.

Interpreta-se este resultado não como uma falha do mecanismo de geração em si, mas como evidência de que o CWE-457 é um alvo inadequado para a abordagem proposta nas condições avaliadas: o teto de *recall* de aproximadamente 31% obtido manualmente, antes mesmo da execução de qualquer modelo (Seção 3.3.1), já está abaixo do limiar mínimo de 50% exigido pelo *gate*, e o modelo de linguagem utilizado sequer se aproximou desse teto já conhecido.

3.4.2 Mecanismo `field_correct`: um ganho real, porém inconsistente

As três rodadas dedicadas ao mecanismo de correção por campo (48 execuções de validação cruzada, Seção 3.3.2) revelam um padrão de efeito real, porém não generalizável. Na combinação C (4 bilhões de parâmetros), o mecanismo não produziu nenhuma diferença mensurável de *recall* em relação à reescrita completa da regra, em nenhum dos quatro arranjos avaliados.

Na combinação D (30 bilhões de parâmetros, *Mixture-of-Experts*), o efeito foi expressivo em um único caso: para o CWE-416 no formato `form`, o `field_correct` elevou o *recall* de 0% para a faixa de 40% a 60%, ao custo de uma taxa de falsos positivos de 20 a 70 vezes superior ao limite de 0,1 alertas por KLOC do *gate*.

Para o formato `formsearch` do mesmo CWE, nenhum efeito foi observado, com ou sem o mecanismo. Para o CWE-415, o efeito foi misto: em alguns casos, o `field_correct` reduziu substancialmente o número de falsos positivos sem alterar de forma relevante o *recall* (por exemplo, de 24 para 0 falsos positivos no formato `formsearch`, mantendo *recall* semelhante); em outros, o mecanismo piorou o resultado, chegando a reduzir o *recall* de 63,8% para 20,6% em uma das sementes do formato `yaml`.

A combinação do `field_correct` com o parâmetro `example_mode=pairs` (Rodada 4) não superou nenhuma das duas configurações isoladamente, e revelou um efeito adicional: o parâmetro `pairs`, quando aplicado ao formato `yaml` do CWE-415, zerou o *recall* em ambas as sementes testadas, independentemente do `field_correct`, evidenciando que nem todo mecanismo validado para um CWE se generaliza para outro.

Conclui-se que o `field_correct` não constitui uma melhoria geral do corretor, mas sim um mecanismo cujo benefício depende da combinação específica de formato, CWE e capacidade do modelo gerador: ele tende a reduzir o ruído de regras já próximas de uma solução estrutural correta, mas não é capaz, por si só, de corrigir uma regra cuja escolha inicial de fonte e sumidouro de contaminação esteja fundamentalmente equivocada.

3.4.3 CWE-416: da aprovação isolada à melhoria consistente

O levantamento das 120 execuções de validação cruzada acumuladas ao longo do trabalho revelou que apenas uma configuração jamais obteve aprovação do *gate*: a combinação D, no formato `template`, com o parâmetro `example_mode=pairs`, aprovando duas das

cinco dobras da sua primeira semente (*recall* de 77,6% e precisão de 73,5% no conjunto de teste), porém nenhuma dobra na segunda semente (apesar de um *recall* de 97,1% nesta última).

Tabela 5 – Evolução da configuração de referência para o CWE-416 (combo D, formato `template`, cinco sementes)

Configuração	***Recall* (faixa)**	**FP (faixa)**	**Sementes com aprovação**
`pairs`	77,6%–97,8%	84–320	1 de 5
`pairs + guard + project_apis`	80,3%–97,1%	619–799	0 de 2
`pairs + guard`	89,2%–100%	12–216	2 de 5

Fonte: Elaborado pelo autor (2026)

A extensão dessa configuração para cinco sementes (Tabela 5) revelou um padrão relevante: o *recall* manteve-se consistentemente elevado em todas as sementes (77,6% a 97,8%), não sendo, portanto, instável.

O que variou entre as sementes foi o número absoluto de falsos positivos no conjunto de teste (84 a 320 ocorrências), situado próximo ao limiar de corte do *gate*; apenas a primeira semente obteve uma contagem suficientemente baixa para ser aprovada. Conclui-se que a aprovação original não foi resultado de uma sorte de *recall*, mas de uma sorte relacionada a exatamente onde a contagem de falsos positivos daquela semente específica recaiu em relação a um corte rígido.

Figura 12 – Falsos positivos por configuração – evolução da regra do CWE-416 (Tabela 5)

[PLACEHOLDER – gráfico a ser criado em SVG pelo autor]
Tipo: gráfico de barras horizontais (ou verticais) em faixa (*range/floating bar*, mínimo–máximo), eixo de contagem em escala logarítmica recomendada (valores cobrem quase duas ordens de grandeza).
Eixo categórico: as três configurações avaliadas, na ordem: `pairs`; `pairs + guard + project_apis`; `pairs + guard` (final).
Eixo de valor: falsos positivos no conjunto de teste.
Faixas (mínimo–máximo): `pairs`: 84–320; `pairs + guard + project_apis`: 619–799; `pairs + guard`: 12–216.
Mensagem visual pretendida: somar `project_apis` ao melhor mecanismo isolado dispara os falsos positivos em cerca de uma ordem de grandeza, e removê-lo novamente (mantendo apenas `guard`) traz a configuração à faixa mais baixa de todo o levantamento – evidenciando visualmente que `project_apis` era a fonte do ruído, não o `guard`.

Fonte: Elaborado pelo autor (2026). Figura a ser substituída por versão em SVG/PDF antes da versão final.

A combinação do parâmetro `pairs` com os mecanismos `guard` e `project_apis` elevou ainda mais o *recall* (80,3% a 97,1% em duas sementes), porém às custas de um aumento

severo de ruído (619 a 799 falsos positivos; 25,6 a 47,3 alertas por KLOC no mundo real), não resultando em nenhuma dobra aprovada.

Por fim, isolando apenas o mecanismo `guard` (sem o `project_apis`) e estendendo para cinco sementes, obteve-se o melhor resultado do trabalho: duas das cinco sementes passaram a obter ao menos uma dobra aprovada (contra apenas uma das cinco sementes da configuração `pairs` isolada), com uma faixa de *recall* mais concentrada (89,2% a 100%).

Esse resultado indica que o parâmetro `project_apis` era o principal responsável pelo ruído adicional observado, e que o mecanismo `guard`, isoladamente, contribui de fato para a confiabilidade da aprovação, sem comprometer o *recall* da configuração de referência.

3.4.4 CWE-415 e a necessidade metodológica de múltiplas sementes

A configuração de referência do CWE-415 (combinação D, formato `yaml`, `example_mode=graph`) nunca obteve aprovação do *gate*, porém suas duas sementes originais apresentaram *recall* de 63,8% e 64,8%, valores próximos entre si que, isoladamente, sugeririam um resultado estável em torno de 64%. A extensão para cinco sementes revelou uma realidade distinta: 63,8%, 64,8%, 47,3%, 43,3% e 76,3%, uma amplitude de 33 pontos percentuais (Tabela 6 e Figura 13).

Tabela 6 – *Recall* por semente de particionamento – configuração de referência do CWE-415 (combo D, `yaml`, `example_mode=graph`)

Semente	***Recall***
1	63,8%
2	64,8%
3	47,3%
4	43,3%
5	76,3%

Fonte: Elaborado pelo autor (2026). Amplitude de 33 pontos percentuais entre a maior e a menor semente; nenhuma delas foi aprovada pelo *gate* (Seção 3.4.5).

Esse achado, somado ao caso do CWE-416 descrito na Seção 3.4.3, evidencia uma lição metodológica central deste trabalho: a variação de resultado entre sementes de particionamento foi, em diversos casos, maior do que o efeito de qualquer mecanismo experimental avaliado (formato de saída, `field_correct`, `example_mode` ou combinação de modelo).

Em um caso específico, a configuração do formato `form` com `field_correct` para o CWE-416 variou de 0% a 60% de *recall* entre duas sementes da mesma configuração exata. Com apenas duas sementes, não é possível distinguir um efeito real do ruído amostral inerente ao processo de particionamento e amostragem de exemplos; a prática adotada na rodada final deste trabalho (cinco sementes por configuração relevante) é recomendada como padrão mínimo para qualquer extensão futura deste *framework*, mesmo ao custo de

Figura 13 – *Recall* por semente – CWE-415 frente ao piso do *gate* e à regra tradicional

[PLACEHOLDER – gráfico a ser criado em SVG pelo autor]
Tipo: gráfico de barras verticais, com duas linhas de referência horizontais.
Eixo X: semente de particionamento (1 a 5).
Eixo Y: *recall* (%), de 0 a 100.
Barras (5, na ordem das sementes): 63,8%; 64,8%; 47,3%; 43,3%; 76,3% (Tabela 6).
Linha de referência 1 (tracejada): 50% – *recall* mínimo exigido pelo *gate*.
Linha de referência 2 (pontilhada): 28,7% – *recall* da regra tradicional do SemGrep para o CWE-415 (Tabela 9).
Mensagem visual pretendida: todas as sementes superam a regra tradicional, mas apenas três das cinco superam o piso do *gate*, e a dispersão entre sementes é maior do que a distância até qualquer uma das duas linhas de referência.

Fonte: Elaborado pelo autor (2026). Figura a ser substituída por versão em SVG/PDF antes da versão final.

uma redução no número de combinações exploradas por unidade de tempo computacional disponível.

3.4.5 O que não foi alcançado: síntese das tentativas sem sucesso e alternativas

É necessário reconhecer, com a mesma transparência empregada na apresentação dos resultados positivos, que diversas tentativas conduzidas ao longo deste trabalho não alcançaram o resultado esperado. O Objetivo Geral desta pesquisa (Seção 1.3.1) estabeleceu a meta de demonstrar desempenho superior às abordagens tradicionais em, no mínimo, cinco categorias de vulnerabilidade.

Ao final das quatro rodadas experimentais, apenas o CWE-416 obteve alguma dobra efetivamente aprovada pelo *gate*, e de forma inconsistente entre sementes (Seção 3.4.3); o CWE-415 aproximou-se, sem jamais ser aprovado; e os CWE-401, CWE-457 e CWE-476 permaneceram com desempenho insuficiente ou pouco explorado. Esta subseção consolida essas tentativas malsucedidas, discute possíveis causas e contrapõe o que foi tentado às estratégias adotadas pelos trabalhos correlatos apresentados na Seção 2.3.

(i) O mecanismo `field_correct` não se generalizou. A expectativa inicial era de que restringir a correção a um único campo por tentativa reduzisse o comportamento, observado nos modelos menores, de reenviar a mesma regra reprovada repetidamente.

O mecanismo cumpriu esse papel pontual, mas não se tornou uma melhoria geral do corretor (Seção 3.4.2): sua eficácia dependeu de uma combinação específica e imprevisível de formato, CWE e porte do modelo gerador, chegando a piorar resultados em alguns arranjos.

Isso indica que o problema central dos modelos menores – a dificuldade de escolher corretamente a fonte e o sumidouro de contaminação de uma regra – não é um problema de granularidade de edição, mas de compreensão semântica da vulnerabilidade, algo que uma correção localizada por campo não é capaz de suprir. Uma alternativa não explorada

seria aplicar o mecanismo de *checker synthesis* orientado por histórico de *patches* de Yang et al. (2025) (KNighter) já na etapa de geração, e não apenas de correção, de forma que a escolha inicial de fonte e sumidouro já nasça ancorada em exemplos reais de correção do próprio CWE, e não apenas na descrição textual do achado do detector.

(ii) O CWE-415 nunca foi aprovado pelo *gate*, apesar de *recall* relevante. Mesmo na sua melhor configuração (`yaml`, `example_mode=graph`, combinação D), o CWE-415 (liberação dupla de memória) jamais atingiu simultaneamente *recall* mínimo de 50% e taxa de falso positivo no mundo real abaixo de 0,1 alertas por KLOC, em nenhuma das cinco sementes avaliadas (Seção 3.4.4).

Diferentemente do CWE-457 (Seção 3.4.1), a causa aqui não era, a esta altura do trabalho, estruturalmente conhecida, e foi inicialmente atribuída de forma difusa à capacidade do modelo gerador de distinguir um padrão de dupla liberação de uma liberação legítima, um raciocínio superficial de fluxo de dados semelhante ao relatado para ferramentas baseadas em LLMs em geral.

Uma investigação posterior, dedicada especificamente a esta e às demais categorias sem solução, identificou uma causa mais precisa e independente do modelo, detalhada no item (vi) adiante.

Como alternativa, a abordagem de Guo et al. (2025) (RepoAudit), que mantém memória entre análises e valida cada candidato a partir da sintaxe concreta do código (via *tree-sitter*) em vez de depender inteiramente de uma regra estática generalizada previamente, poderia reduzir esse tipo de erro ao analisar cada ocorrência em seu contexto real, ao custo de abandonar o objetivo de produzir uma regra reutilizável e de baixo custo de inferência recorrente, que é a proposta central deste trabalho (Seção 1.4).

(iii) Combinar os dois melhores mecanismos conhecidos piorou o resultado. A tentativa de somar o único parâmetro já aprovado (`example_mode=pairs`) aos mecanismos de maior *recall* já observados (`guard` e `project_apis`) partiu da hipótese de que efeitos positivos isolados se somariam.

O resultado mostrou o oposto: a taxa de falsos positivos aumentou em uma ordem de grandeza (Tabela 5), e o isolamento posterior do `project_apis` como variável causadora só foi possível por meio de uma rodada adicional dedicada exclusivamente a essa decomposição. O ganho de contexto (mais informação no *prompt*, como os nomes de funções do projeto) não é garantia de ganho de precisão, podendo inclusive ser contraproducente quando o contexto adicional não está suficientemente alinhado à semântica da vulnerabilidade – um risco já discutido teoricamente na Seção 1.1 ao abordar os limites do *self-attention* sobre janelas de contexto extensas (VASWANI et al., 2017).

(iv) O CWE-457 permanece sem solução dentro da abordagem proposta. Diferentemente dos casos anteriores, aqui a causa raiz é conhecida e documentada antes mesmo da execução de qualquer experimento (Seção 3.3.1): o motor do SemGrep *Open Source* não inicia rastreamento de contaminação a partir de uma declaração sem atribuição

de valor. Não se trata, portanto, de uma falha do *framework* proposto, mas de uma limitação da ferramenta-alvo (SemGrep) para este CWE específico em sua variante *Open Source*.

Duas alternativas foram cogitadas, porém não implementadas por estarem fora do escopo de síntese de regras SemGrep definido neste trabalho (Seção 1.4): (a) a utilização da versão comercial do SemGrep (*Semgrep Pro*), cujo motor de fluxo de dados interprocedural é mais completo; e (b) a geração de um analisador dedicado e independente do SemGrep, nos moldes do *checker* standalone sintetizado por Yang et al. (2025), que não herda as mesmas restrições de modo *taint* por não depender da infraestrutura do SemGrep.

Em conjunto, esses quatro casos sugerem uma conclusão mais ampla: a comparação com Hou et al. (2025) e Yang et al. (2025) indica que a dificuldade central deste trabalho – equilibrar *recall* e taxa de falsos positivos em código real – não é exclusiva da arquitetura aqui proposta, mas uma limitação recorrente relatada de forma consistente em toda a literatura revisada sobre análise estática assistida por LLMs.

A diferença observada entre os trabalhos correlatos e esta pesquisa está menos no problema em si e mais na escala de validação: enquanto Guo et al. (2025) avalia dezenas de repositórios reais com revisão manual extensiva, este trabalho validou um número reduzido de combinações sobre um único repositório de negativos (*git/git*) e o *dataset* sintético do Juliet Test Suite, o que limita a generalização dos resultados aqui obtidos e é retomado como limitação formal no Capítulo 4.

(v) Os achados do analisador de grafos de eventos (Seção 3.2.5), apesar de mais precisos, não produziram regras mais silenciosas. Substituir os achados do detector inicial pelos achados do analisador de grafos como exemplo de treinamento (`example_mode=graph`) elevou o *recall* da combinação D no CWE-416 de 71,6% para 91,6%, porém às custas de uma queda de precisão de 89,4% para 69,8%, de um aumento de falsos positivos no Juliet de 9,0 para 29,4 e de uma elevação da taxa de alerta no mundo real de 2,53 para 4,76 alertas por KLOC (Tabela 7): a regra tornou-se mais abrangente, não mais silenciosa.

Tabela 7 – Efeito de `example_mode=graph` sobre a combinação D no CWE-416

Métrica	**Achados do detector**	**Achados do grafo**
Recall	71,6%	91,6%
Precisão	89,4%	69,8%
Falsos positivos (Juliet)	9,0	29,4
Alertas/KLOC (mundo real)	2,53	4,76

Fonte: Elaborado pelo autor (2026). A regra tornou-se mais abrangente, não mais silenciosa.

A causa, identificada por leitura manual das regras geradas, é estrutural: a descrição

de um achado do grafo ("liberado na linha a, usado na linha b") informa ao modelo *onde* está o defeito, mas não *o que* a regra deve excluir – a própria linha de liberação, sendo também um uso do ponteiro segundo a definição do padrão de sumidouro da regra, acaba capturada pela regra gerada, e nada na descrição do achado instrui o modelo a excluí-la.

Para o CWE-476 (desreferência de ponteiro nulo), o mesmo experimento expôs uma limitação mais fundamental, da linguagem de regras do SemGrep e não do modelo: a consulta do analisador de grafos só se mantém silenciosa ao exigir que nenhuma decisão de fluxo de controle ocorra entre o evento nulo e a desreferência, uma condição que a linguagem de padrões do SemGrep não é capaz de expressar; diante dos achados do grafo como exemplo, o modelo de 30 bilhões de parâmetros produziu regras que, em 5 das 10 dobras, não casavam com nenhum trecho de código e, nas demais, casavam com praticamente qualquer desreferência de ponteiro (*recall* de 51% a 80%, acompanhado de 110 a 145 alertas por KLOC) – não havia, para o modelo, um padrão intermediário entre esses dois extremos.

Um achado adicional, obtido ao compilar diretamente a lógica do analisador de grafos em uma regra SemGrep fixa (sem nenhum modelo de linguagem envolvido, apenas um padrão de *taint* com uma exclusão por `not_inside`), qualifica o próprio critério de aprovação adotado neste trabalho: essa regra foi aprovada em 10 das 10 dobras do CWE-416 (*recall* de 52,0%, zero falsos positivos no Juliet, 0,06 alertas por KLOC), mas a leitura manual dos 22 alertas que ela emitiu sobre o código real de referência não encontrou nenhum defeito verdadeiro entre eles – eram laços que liberam um elemento e usam o seguinte, reatribuições por meio de macros ou funções que o extrator não conseguia enxergar, e entradas de tabela de dispersão (*hash*) readicionadas por outro caminho.

Esse achado reforça uma ressalva metodológica importante para a interpretação de todos os resultados deste trabalho: a aprovação pelo *gate* – *recall* mínimo, zero falsos positivos no Juliet, baixa taxa de alerta em código real – é uma propriedade do comportamento da regra sobre este conjunto específico de dados de referência, não uma garantia de que os alertas que ela produziria sobre outro código real correspondam a defeitos verdadeiros.

(vi) CWE-401, CWE-415 e CWE-476 compartilham uma causa raiz comum, nomeada com precisão em uma investigação final: um limite da própria linguagem de padrões do SemGrep, não do modelo gerador ou da estratégia de busca empregada. Após o encerramento das quatro rodadas experimentais, uma investigação dedicada testou se os achados do analisador de grafos de eventos (Seção 3.2.5), ainda não utilizados como exemplo para o CWE-401, e um formato ainda não testado para o CWE-476 (`formsearch` com achados do grafo) poderiam reverter esses dois casos.

Nenhum dos dois reverteu: o CWE-401 atingiu apenas 25,2% e 25,7% de *recall* nas duas sementes avaliadas – abaixo inclusive do piso de 50% exigido apenas para validade estrutural, sem sequer considerar o critério de ruído no mundo real –, o pior resultado entre os quatro CWEs já testados com achados do grafo como exemplo; o CWE-476 em

`formsearch` obteve 4,2% e 0% de *recall*, inferior ao já obtido em formato livre (23,9%, Seção 3.4.2) – resumido na Tabela 8.

Tabela 8 – Experimentos finais de diagnóstico – CWE-401 e CWE-476

CWE	**Mecanismo testado**	***Recall***	**Resultado**
CWE-401	Achados do grafo como exemplo (2 sementes)	25,2%; 25,7%	Abaixo do piso de 50% exigido pelo *gate*
CWE-476	`formsearch` + achados do grafo (2 sementes)	4,2%; 0%	Inferior ao já obtido em formato livre (23,9%)

Fonte: Elaborado pelo autor (2026).

Essa investigação, somada à correção de um defeito até então não diagnosticado no gerador determinístico por síntese (`method_synthesis`): uma exclusão `not_inside` que, aplicada de forma genérica a todo CWE, excluía para o CWE-415 a própria ocorrência que deveria confirmar o achado, por fonte e sumidouro de contaminação serem, nesse caso, exatamente o mesmo padrão sintático (`free($P)`) – permitiu nomear, para cada um dos três CWEs ainda sem solução, uma razão específica e verificada, e não mais hipotética, pela qual nenhuma regra SemGrep consegue expressar a condição que separa um achado verdadeiro de um falso, independentemente de quem ou o que a escreve:

- **CWE-401** (vazamento de memória): a condição de interesse – "não foi liberado, não foi repassado adiante, não foi retornado antes do fim da função" – é um argumento de vivacidade (*liveness*) sobre todos os caminhos até todas as saídas da função, não uma relação entre dois pontos fixos de código (uma fonte e um sumidouro) que uma regra de *taint* possa nomear;
- **CWE-415** (liberação dupla): a fonte e o sumidouro de contaminação são, por definição da própria vulnerabilidade, exatamente o mesmo padrão sintático (`free($P)`); o motor de *taint* do SemGrep casa essa única ocorrência contra si mesma, e nenhum operador da linguagem de padrões disponível distingue "esta ocorrência" de "uma ocorrência posterior da mesma forma";
- **CWE-476** (desreferência de ponteiro nulo): a ausência de um teste não nulo em qualquer caminho entre o evento nulo e a desreferência é uma condição sobre caminhos de fluxo de controle, não uma forma sintática única que possa ser nomeada e excluída de uma vez, como fez o `pattern-not` do CWE-457 (Seção 3.4.1).

O fato de essas três causas se manterem idênticas através de métodos tão distintos quanto um modelo de 30 bilhões de parâmetros orientado pelos achados do grafo, um gerador determinístico por síntese de padrões e um programa que compila a lógica do

grafo diretamente em uma regra fixa (item (v) anterior) é, em si, a evidência mais forte deste trabalho de que o limite não está na busca, mas no destino dela: toda tentativa testada escreve uma regra SemGrep, e nenhuma delas muda o que essa linguagem é capaz de expressar.

A alternativa concreta que esse diagnóstico aponta – direcionar um motor de análise com sensibilidade a caminho (como o CodeQL ou o Joern), ou disponibilizar diretamente as consultas do próprio analisador de grafos de eventos (Seção 3.2.5) como detector, em vez de compilá-las em uma regra SemGrep – está fora do escopo de síntese de regras definido para este trabalho (Seção 1.4), mas é registrada aqui como a conclusão mais precisa obtida sobre por que estes três CWEs permanecem sem solução, e retomada como trabalho futuro no Capítulo 4.

3.4.6 Comparação com um analisador estático tradicional

Para avaliar diretamente o Objetivo Específico 2 (Seção 1.3.2) e a Hipótese de pesquisa (Seção 1.3.3), buscou-se uma linha de base de comparação externa ao *framework* proposto. O registro público (*registry*) gratuito do SemGrep, acessível sem autenticação, disponibiliza o pacote `r/c` (73 regras para a linguagem C, das quais 16 aplicáveis ao *dataset* utilizado), do qual duas regras mostraram-se diretamente relevantes para os CWEs avaliados neste trabalho: `c.lang.security.function-use-after-free`, para o CWE-416, e `c.lang.security.double-free` (que, nos arquivos avaliados, ocorre acompanhada de ocorrências adicionais da regra de uso após liberação), para o CWE-415.

Nenhuma regra relevante foi encontrada no mesmo pacote para o CWE-401, o CWE-457 ou o CWE-476 – para o primeiro, a única regra disparada (detecção insegura de funções de cópia de *string*) não corresponde ao padrão de vazamento de memória avaliado; para os demais dois, nenhuma regra do pacote foi acionada em nenhum arquivo do *dataset* –, de forma que a comparação direta ficou restrita às duas categorias em que o *framework* proposto também obteve os melhores resultados.

As regras tradicionais foram executadas sobre a totalidade do subconjunto Juliet rotulado para cada CWE (300 arquivos para o CWE-416, 760 para o CWE-415, divididos igualmente entre código vulnerável e seguro), e seu *recall*, precisão e F1-Score foram calculados pelo mesmo critério de agrupamento por caso de teste utilizado na avaliação das regras sintetizadas (Seção 3.2.7). A Tabela 9 apresenta o resultado, contrapondo-o à faixa de valores obtida pela melhor configuração sintetizada de cada CWE ao longo das cinco sementes avaliadas (Seções 3.4.3 e 3.4.4).

Em ambos os CWEs, a melhor configuração sintetizada por este trabalho superou a regra tradicional em *recall* em todas as cinco sementes avaliadas, sem exceção: o menor valor de *recall* obtido pela configuração sintetizada (43,3%, CWE-415) ainda supera o da regra tradicional para o mesmo CWE (28,7%); o mesmo padrão se repete, com margem

Tabela 9 – Comparação entre as regras sintetizadas e um analisador tradicional (registro público do SemGrep, pacote `r/c`)

CWE	**Abordagem**	***Recall***	**Precisão**	**F1**
CWE-416	Regra tradicional (`r/c`)	17,4%	66,7%	0,276
	Melhor regra sintetizada	89,2%–100%	56,1%–92,4%	0,72–0,91
CWE-415	Regra tradicional (`r/c`)	28,7%	50,0%	0,364
	Melhor regra sintetizada	43,3%–76,3%	41,6%–59,7%	0,50–0,63

Fonte: Elaborado pelo autor (2026). A regra tradicional foi avaliada sobre a totalidade do subconjunto Juliet rotulado do CWE; a regra sintetizada, por validação cruzada de cinco dobras e cinco sementes sobre o conjunto de teste isolado.

Figura 14 – Comparação visual: regra tradicional *versus* melhor regra sintetizada (CWE-416 e CWE-415)

[PLACEHOLDER – gráfico a ser criado em SVG pelo autor]
Tipo: duas pequenas múltiplas (*small multiples*) lado a lado, uma por CWE; em cada uma, gráfico de barras agrupadas por métrica (*Recall*, Precisão, F1×100), com duas barras por métrica: "Tradicional" (valor único) e "Sintetizada" (barra em faixa mínimo–máximo, com hastes de erro).
Eixo Y: 0 a 100 (F1 multiplicado por 100 para compartilhar a escala com *recall*/precisão; indicar isso na legenda do eixo).
Painel CWE-416: Tradicional – *recall* 17,4%, precisão 66,7%, F1 27,6; Sintetizada – *recall* 89,2%–100%, precisão 56,1%–92,4%, F1 72–91.
Painel CWE-415: Tradicional – *recall* 28,7%, precisão 50,0%, F1 36,4; Sintetizada – *recall* 43,3%–76,3%, precisão 41,6%–59,7%, F1 50–63.
Mensagem visual pretendida: a regra sintetizada supera a tradicional em *recall* e F1 nos dois CWEs, sem exceção, enquanto a precisão mostra sobreposição entre as faixas – o ganho não é absoluto em todas as métricas, apenas no saldo medido pelo F1 (Tabela 9).

Fonte: Elaborado pelo autor (2026). Figura a ser substituída por versão em SVG/PDF antes da versão final.

ainda maior, no CWE-416 (menor valor sintetizado de 89,2% contra 17,4% da regra tradicional).

Em F1-Score, a vantagem é igualmente consistente: 0,72 a 0,91 contra 0,276 no CWE-416, e 0,50 a 0,63 contra 0,364 no CWE-415. A precisão, por sua vez, apresenta um quadro mais equilibrado – em algumas sementes a regra tradicional supera a configuração sintetizada (por exemplo, 66,7% contra 56,1% na semente de menor precisão do CWE-416), evidenciando que o ganho de *recall* do *framework* proposto não ocorre sem nenhum custo de precisão, ainda que o ganho líquido, medido pelo F1-Score, seja favorável em todas as sementes avaliadas.

Interpreta-se este resultado como a evidência mais direta e quantitativa, dentre todas as obtidas neste trabalho, em favor da Hipótese de pesquisa (Seção 1.3.3): nas duas categorias

de CWE em que uma regra tradicional comparável pôde ser identificada no registro público e gratuito do SemGrep, a síntese dinâmica de regras por LLMs superou-a de forma consistente em *recall* e F1-Score, confirmando, ainda que não de forma generalizada a todas as cinco categorias originalmente previstas, a premissa central deste trabalho.

Ressalva-se que a regra tradicional foi avaliada sobre a totalidade do conjunto rotulado, sem necessidade de particionamento (por não ser uma abordagem treinada ou ajustada aos dados), enquanto a regra sintetizada foi avaliada por validação cruzada sobre dados de teste isolados; a comparação, ainda assim, segue o padrão estabelecido na literatura de avaliação empírica de ferramentas de análise estática (GUO et al., 2025).

4 Conclusão

4.1 Retomada do problema e dos objetivos

A pergunta de pesquisa que orientou este trabalho (Seção 1.2) questionava se um *framework* baseado em LLMs seria capaz de sintetizar regras para o SemGrep com *recall* e precisão estatisticamente superiores ao *ruleset* tradicional da ferramenta, para vulnerabilidades de gerenciamento de memória em C.

A resposta obtida é condicional, não categórica: sim, para duas das cinco categorias de CWE originalmente delimitadas (CWE-416 e CWE-415), nas quais uma comparação direta contra uma regra tradicional pôde ser estabelecida e superada em *recall* e F1-Score em todas as sementes avaliadas (Seção 3.4.6); não demonstrada, para as demais três (CWE-401, CWE-457 e CWE-476), nas quais nenhuma configuração testada atingiu o critério interno de aprovação deste trabalho, por razões distintas e específicas a cada CWE (Seção 3.4.5).

O Objetivo Geral (Seção 1.3.1) – generalizar essa superioridade a, no mínimo, cinco categorias de CWE – não foi plenamente alcançado, e essa divergência entre o planejado e o obtido é, como discutido na própria Seção 1.3.1, mantida como resultado honesto do processo experimental, não como meta reformulada *a posteriori* (WAZLAWICK, 2020).

Dos três Objetivos Específicos (Seção 1.3.2), o primeiro (delimitar os limites semânticos da abordagem gerativa frente a *rulesets* estáticos) e o terceiro (viabilizar a execução em modelos de menor escala e infraestrutura local) foram plenamente alcançados; o segundo (comparação quantitativa com analisadores tradicionais) foi parcialmente alcançado, restrito às duas categorias de CWE para as quais uma regra tradicional comparável existe no registro público e gratuito do SemGrep.

A Hipótese de pesquisa (Seção 1.3.3) acompanha esse mesmo padrão: refutada em sua formulação ampla, generalizada a todas as categorias previstas, e não refutada nos dois casos – CWE-416 e CWE-415 – em que a evidência quantitativa pôde ser produzida.

Interpretado como um todo, o processo de validação cruzada de mais de cem execuções realizado ao longo deste trabalho (Seções 3.4.3 a 3.4.6), complementado por uma investigação final dedicada especificamente às três categorias ainda sem solução, produziu uma resposta mais estreita e mais precisa do que a pergunta de pesquisa original antecipava.

A dificuldade não está distribuída igualmente entre categorias de CWE, nem é atribuível de forma difusa à capacidade do modelo gerador, mas concentrada em limites nomeados e específicos da própria linguagem de padrões do SemGrep – a ausência de um ponto de partida de contaminação em uma declaração sem valor (CWE-457); a inexistência, na linguagem de padrões, de um argumento de vivacidade sobre todos os caminhos de uma

função (CWE-401); a identidade sintática entre fonte e sumidouro de contaminação, que o motor de *taint* do SemGrep casa contra si mesma (CWE-415); e a natureza de condição sobre caminhos, e não de forma sintática única, da ausência de teste que separa um achado verdadeiro de um falso (CWE-476) –, limites que se mantiveram idênticos através de métodos tão distintos quanto um modelo de linguagem, um gerador determinístico por síntese e um programa que compila a lógica de detecção diretamente em uma regra fixa (Seção 3.4.5).

4.2 Contribuições para a Computação

Independentemente do grau de sucesso quantitativo obtido em cada categoria de CWE, este trabalho produz contribuições de natureza metodológica e empírica para a área de análise estática assistida por modelos de linguagem, organizadas segundo os quatro tipos de artefato do *Design Science Research* (HEVNER et al., 2004) adotados como método (Seção 3.1):

1. **Constructo**: a caracterização, em cinco formatos de saída de regra progressivamente mais restritos (`yaml`, `spec`, `template`, `form` e `formsearch`, Seção 3.2.4), do compromisso entre liberdade sintática do modelo gerador e capacidade de direcionar sua saída a uma estrutura de regra sabidamente eficaz – uma dimensão de projeto não discutida nos trabalhos correlatos revisados (Seção 2.3), que tratam o formato de saída do modelo como uma decisão de implementação, e não como uma variável experimental.

2. **Método**: o mecanismo de correção por campo (`field_correct`, Seção 3.2.4) e sua caracterização experimental como um ganho real, porém condicionado à capacidade do modelo de base e ao formato de regra (Seção 3.4.2) – um resultado tão negativo quanto positivo, que delimita quando esse tipo de correção granular é, e não é, uma estratégia útil para modelos de linguagem de pequeno porte em tarefas de síntese de código estruturado.

3. **Modelo**: a demonstração empírica, obtida ao se estender a avaliação de duas para cinco sementes de particionamento (Seção 3.4.4), de que a variação amostral entre sementes pode exceder o efeito de qualquer mecanismo experimental avaliado – um alerta metodológico com implicação direta para a validade de resultados reportados com poucas repetições em trabalhos futuros desta mesma linha de pesquisa, dentro ou fora deste *framework*.

4. **Instanciação**: o *pipeline* completo e executável (gerador, corretor, *gate* determinístico e protocolo de validação cruzada), capaz de operar inteiramente em *hardware* de consumo com modelos de linguagem locais de código aberto, disponibilizado como

ferramenta reutilizável para a síntese e avaliação de regras do SemGrep em outras categorias de vulnerabilidade.

Contribui-se ainda com um diagnóstico que distingue, para as três categorias de CWE que permaneceram sem solução após todas as rodadas experimentais (CWE-401, CWE-415 e CWE-476), um limite de **busca** de um limite de **linguagem-alvo**: uma investigação dedicada (Seção 3.4.5) mostrou que nenhum dos mecanismos avaliados neste trabalho – variação do *prompt* e dos exemplos mostrados ao modelo, variação do corretor, ou mesmo a substituição completa do modelo por um gerador determinístico – muda o resultado, porque todos produzem, como artefato final, uma regra na mesma linguagem de padrões do SemGrep, e é essa linguagem, não o método de busca dentro dela, que não comporta a condição exigida por cada um desses três CWEs.

Essa distinção generaliza-se para além deste trabalho: ao se investigar por que uma abordagem de síntese de regras não converge para um CWE específico, convém primeiro verificar se a linguagem-alvo é, em princípio, capaz de expressar a condição que distingue um achado verdadeiro de um falso, antes de se investir em variações do método de síntese em si.

Contribui-se, por fim, com uma constatação de ordem epistemológica para a avaliação de qualquer ferramenta de análise estática assistida por modelos de linguagem, levantada ao se comparar os achados do analisador de grafos de eventos com a síntese de regras por LLM (Seção 3.2.5): uma regra pode satisfazer integralmente um critério de aprovação quantitativo – *recall* mínimo no conjunto de teste, zero falsos positivos no *dataset* sintético, baixa taxa de alerta em código real – sem que seus alertas individuais correspondam a defeitos verdadeiros quando lidos manualmente (Seção 3.4.5), o que reforça, para além deste trabalho, a necessidade de revisão manual amostral como complemento a qualquer métrica agregada de avaliação de regras de análise estática, prática já adotada por Guo et al. (2025) e incorporada neste trabalho a partir da comparação com o analisador de grafos.

4.3 Limitações e trabalhos futuros

As limitações deste trabalho foram discutidas em detalhe na Seção 3.4.5; esta seção as retoma de forma sintética e aponta encaminhamentos concretos para trabalhos futuros.

Em primeiro lugar, o Objetivo Geral de demonstrar desempenho superior em, no mínimo, cinco categorias de CWE (Seção 1.3.1) não foi plenamente alcançado: apenas o CWE-416 obteve dobras aprovadas pelo *gate*, e de forma instável entre sementes de particionamento; o CWE-415 chegou perto, sem jamais ser aprovado; e os CWE-401, CWE-457 e CWE-476 não ultrapassaram a fase exploratória.

Essa limitação é, em si, um resultado relevante: ela indica que a dificuldade relatada pela literatura em equilibrar *recall* e falsos positivos (Seção 2.3) se manifesta igualmente na arquitetura aqui proposta, e que a escala de validação deste trabalho (um único

repositório de negativos do mundo real, um número reduzido de sementes por configuração) é insuficiente para generalizar a eficácia do *framework* para categorias de vulnerabilidade além do CWE-416 e do CWE-415, as duas únicas em que uma comparação direta contra um analisador tradicional pôde ser estabelecida (Seção 3.4.6) e nas quais a hipótese de pesquisa não foi refutada.

Como trabalhos futuros, propõe-se:

(i) Validar as configurações já aprovadas sobre múltiplos repositórios de negativos do mundo real, e não apenas o *git/git*, de forma a confirmar que a taxa de falso positivo observada não é específica daquele projeto;

(ii) Incorporar, à semelhança de Yang et al. (2025), o histórico de *patches* de correção do próprio CWE já na etapa de geração da regra, não apenas como exemplo textual, mas como fonte estruturada de padrões de fonte e sumidouro de contaminação;

(iii) Investigar arquiteturas alternativas baseadas em agentes com memória e validação sintática concreta, nos moldes de Guo et al. (2025), como alternativa complementar para os CWEs em que a síntese de uma regra estática generalizável se mostrou mais difícil (CWE-415 e CWE-457);

(iv) Estender toda e qualquer configuração considerada promissora para, no mínimo, cinco sementes de particionamento antes de reportá-la como resultado, prática adotada apenas na etapa final deste trabalho (Seção 3.4.4) e que se mostrou necessária para distinguir um efeito real do ruído amostral do processo de validação cruzada;

(v) Obter uma linha de base tradicional para o CWE-401, o CWE-457 e o CWE-476, categorias para as quais o registro gratuito do SemGrep não ofereceu nenhuma regra relevante (Seção 3.4.6), seja por meio de uma versão paga de um analisador (como o *Semgrep Pro*), de outra ferramenta de análise estática do estado da arte (como o CodeQL), ou de uma regra manualmente especializada escrita por um especialista;

(vi) Para o CWE-401, o CWE-415 e o CWE-476, cujo obstáculo uma investigação final diagnosticou precisamente como um limite da própria linguagem de padrões do SemGrep, e não do modelo gerador ou da estratégia de busca (um argumento de vivacidade sobre todos os caminhos da função, no primeiro; uma fonte e um sumidouro de contaminação sintaticamente idênticos, que o motor de *taint* do SemGrep casa contra si mesmo, no segundo; e uma condição sobre caminhos de fluxo de controle, não uma forma sintática única a excluir, no terceiro – Seção 3.4.5), investigar um motor de análise estática com sensibilidade a caminho, capaz de expressar essas três condições nativamente (como o CodeQL ou o Joern), ou, alternativamente, disponibilizar diretamente as consultas do analisador de grafos de eventos deste trabalho (Seção 3.2.5) – que já expressa essas mesmas condições em sua própria lógica de busca – como detector autônomo, independente de qualquer regra SemGrep.

Referências Bibliográficas

AHO, A. V. et al. *Compilers: Principles, Techniques, and Tools*. 2nd. ed. [S.l.]: Addison-Wesley, 2007. ISBN 0-321-48681-1. 13, 25, 26, 27, 28, 29, 43

CVE Program. *About CVE*. 2026. Disponível em: <https://www.cve.org/About/Overview>. Acesso em: 4 jun. 2026. 11, 32

DAO, T. et al. FlashAttention: Fast and memory-efficient exact attention with IO-awareness. In: *Advances in Neural Information Processing Systems 35 (NeurIPS 2022)*. [S.l.: s.n.], 2022. 15, 39

DURUMERIC, Z. et al. The matter of Heartbleed. In: *Proceedings of the 2014 Conference on Internet Measurement Conference (IMC '14)*. Vancouver, Canada: ACM, 2014. p. 475–488. 11

GUO, J. et al. RepoAudit: An autonomous LLM-agent for repository-level code auditing. In: *Proceedings of the 42nd International Conference on Machine Learning*. [s.n.], 2025. Disponível em: <https://openreview.net/pdf?id=TXcifVbFpG>. 9, 16, 41, 42, 44, 49, 50, 51, 67, 68, 73, 76, 77

HEVNER, A. R. et al. Design science in information systems research. *MIS Quarterly*, JSTOR, v. 28, n. 1, p. 75–105, 2004. Disponível em: <https://wise.vub.ac.be/sites/default/files/thesis_info/design_science.pdf>. 53, 60, 75

HOU, Z. et al. Generation, migration and optimization of cross-language static-analysis rules based on large language models. In: *Proceedings of the 2025 IEEE/ACM International Conference on Software Engineering (ICSE)*. [s.n.], 2025. Disponível em: <https://ieeexplore.ieee.org/document/11173453/>. 9, 11, 12, 13, 15, 17, 21, 29, 30, 44, 47, 48, 49, 68

JIANG, Z. et al. Fact-aligned and template-constrained static analyzer rule enhancement with llms. In: *Proceedings of the 40th IEEE/ACM International Conference on Automated Software Engineering (ASE)*. [S.l.: s.n.], 2025. 12, 13, 29, 30

JURAFSKY, D.; MARTIN, J. H. *Speech and Language Processing: An Introduction to Natural Language Processing, Computational Linguistics, and Speech Recognition*. 3rd draft. ed. [s.n.], 2026. Em preparação. Disponível em: <https://web.stanford.edu/~jurafsky/slp3/ed3book_jan26.pdf>. 14, 36, 37, 38, 39, 40, 41

MITRE Corporation. *CWE - Common Weakness Enumeration*. 2026. <https://cwe.mitre.org/>. Acessado em: 3 de junho de 2026. 11, 32, 33

MITRE Corporation. *CWE-401: Missing Release of Memory after Effective Lifetime*. 2026. <https://cwe.mitre.org/data/definitions/401.html>. Acessado em: 4 de junho de 2026. 33

MITRE Corporation. *CWE-415: Double Free*. 2026. <https://cwe.mitre.org/data/definitions/415.html>. Acessado em: 4 de junho de 2026. 34, 35

MITRE Corporation. *CWE-416: Use After Free*. 2026. <https://cwe.mitre.org/data/definitions/416.html>. Acessado em: 4 de junho de 2026. 34

MITRE Corporation. *CWE-457: Use of Uninitialized Variable*. 2026. <https://cwe.mitre.org/data/definitions/457.html>. Acessado em: 4 de junho de 2026. 35

MITRE Corporation. *CWE-476: NULL Pointer Dereference*. 2026. <https://cwe.mitre.org/data/definitions/476.html>. Acessado em: 4 de junho de 2026. 35, 36

NSA Center for Assured Software. *Juliet C/C++ 1.3 - NIST Software Assurance Reference Dataset (SARD) Test Suite #112*. [S.l.]: National Institute of Standards and Technology (NIST), 2017. <https://samate.nist.gov/SARD/test-suites/112>. Acesso em: 29 maio 2026. 42, 47, 54, 60

RUSSELL, S.; NORVIG, P. *Artificial Intelligence: A Modern Approach*. 4. ed. Hoboken: Pearson, 2020. ISBN 978-0134610993. 16, 41

SEACORD, R. C. *Secure Coding in C and C++*. 2nd. ed. Addison-Wesley Professional, 2013. ISBN 978-0321822130. Disponível em: <https://raw.githubusercontent.com/DarkCodeOrg/welcome-to-cybersecurity/master/securecodingincandc++.pdf>. Acesso em: 27 abr. 2026. 31, 32

Software Engineering Institute. *SEI CERT C Coding Standard: Rules for Developing Safe, Reliable, and Secure Systems*. 2016 edition. ed. Carnegie Mellon University, 2016. Acessado em: 12 de novembro de 2026. Disponível em: <https://chenweixiang.github.io/docs/SEI_CERT_C_Coding_Standard_2016_Edition.pdf>. 31, 33

TANG, Y. et al. Grammar-based patches generation for automated program repair. In: *Findings of the Association for Computational Linguistics: ACL-IJCNLP 2021*. Association for Computational Linguistics, 2021. p. 1300–1305. Disponível em: <https://aclanthology.org/2021.findings-acl.111/>. 13

The Chromium Projects. *Memory safety*. [2020]. Chromium Security. Disponível em: <https://www.chromium.org/Home/chromium-security/memory-safety/>. Acesso em: 2 nov. 2026. 11

THOMAS, G. *A proactive approach to more secure code*. 2019. Microsoft Security Response Center Blog, 16 jul. 2019. Disponível em: <https://www.microsoft.com/en-us/msrc/blog/2019/07/a-proactive-approach-to-more-secure-code>. Acesso em: 2 nov. 2026. 11

TUNSTALL, L.; WERRA, L. von; WOLF, T. *Natural Language Processing with Transformers: Building Language Applications with Hugging Face*. Sebastopol, CA: O'Reilly Media, Inc., 2022. ISBN 978-1098103248. 15, 37, 38

VASWANI, A. et al. Attention is all you need. In: *31st Conference on Neural Information Processing Systems (NIPS 2017)*. Long Beach, CA, USA: [s.n.], 2017. 14, 15, 37, 38, 39, 67

WAZLAWICK, R. S. *Metodologia de Pesquisa para Ciência da Computação*. Rio de Janeiro: Elsevier Brasil, 2020. 18, 20, 53, 74

YANG, C. et al. Knighter: Transforming static analysis with llm-synthesized checkers. *arXiv preprint arXiv:2503.09002*, 2025. Disponível em: <https://arxiv.org/abs/2503.09002>. 9, 12, 13, 14, 16, 17, 21, 42, 44, 45, 46, 47, 48, 49, 67, 68, 77